BULUT GÜVENLİĞİ ve KİMLİK YÖNETİMİ

İÇİNDEKİLER

BULUT GÜVENLİĞİ ve KİMLİK YÖNETİMİ 1
Tablolar Listesi 2
Şekiller Listesi 2
1. Dersin Amacı ve Öğrenme Çıktıları 3
1.1. Haftanın Amacı ve Bulutta Güvenliğin Yeri 3
1.2. Öğrenme Çıktıları 3
2. Bulutta Güvenlik Hedefleri ve Sorumluluk Paylaşımı 4
2.1. Gizlilik, Bütünlük ve Kullanılabilirlik 4
2.2. Varlıklar, Tehditler ve Güven Sınırları 5
2.3. Hizmet Modellerine Göre Sağlayıcı ve Müşteri Görevleri 7
2.4. Yanlış Yapılandırma ve Çok Kiracılı Ortamda İzolasyon 9
3. Kimlik Yönetimi ve Kimlik Doğrulama 10
3.1. Kimlik ve Kimlik Bilgisi Ayrımı 10
3.2. Kimlik Doğrulama ve Yetkilendirme Ayrımı 11
3.3. İnsan Kimlikleri ve Çok Etmenli Doğrulama 13
3.4. Uygulama ve Servis Kimlikleri 14
3.5. Federasyon, Kısa Ömürlü Kimlik Bilgileri ve Yaşam Döngüsü 16
4. Yetkilendirme ve En Az Ayrıcalık 18
4.1. Erişim İsteği ve Yetkilendirme Kararı 18
4.2. Rol ve Nitelik Tabanlı Erişim Denetimi 19
4.3. En Az Ayrıcalık ve Etkili İzinler 21
4.4. Yönetim Yetkileri ve Uygulama Erişim Sınırları 22
5. Sıfır Güven ve Katmanlı Erişim 24
5.1. Sıfır Güven Yaklaşımı ve Erişim Bağlamı 24
5.2. Katmanlı Güvenlik Kontrollerinin Birlikte Uygulanması 25
6. Sırlar ve Uygulama Kimlik Bilgilerinin Yönetimi 26
6.1. Sırların Güvenli Saklanması ve Uygulamaya Sağlanması 27
6.2. Sırların Yenilenmesi, İptali ve Sızıntıya Müdahale 28
7. Şifreleme ve Anahtar Yönetimi 28
7.1. Bulutta Şifrelemenin Kullanımı ve Sınırları 29
7.2. Anahtar Yönetimi ve Zarf Şifreleme 29
7.3. Anahtar Yaşam Döngüsü ve Veri Erişimine Etkileri 30
8. Bulut Senaryosu: Güvenli Rapor Yükleme ve Paylaşma 31

9. Bölüm Özeti....34
Kaynakça....35
Hafta 8 – Çalışma Soruları....37

Tablolar Listesi

Tablo 1. Bulut sisteminde örnek tehditler ve uygun güvenlik kontrolleri....6
Tablo 2. Hizmet Modellerine Göre Genel Güvenlik Sorumlulukları....8
Tablo 3. Kimlik, Tanımlayıcı ve Doğrulamada kullanılan bilgi örnekleri....11
Tablo 4. Doğrulanmış bir kimlik için farklı yetkilendirme kararları....12
Tablo 5. Temel Doğrulama Etmenleri....13
Tablo 6. Proje Teslim Sisteminde Uygulama Kimliklerinin Ayrılması....15
Tablo 7. Erişim isteğinin temel bileşenleri....18
Tablo 8. Rol ve nitelik tabanlı erişim denetiminin karşılaştırılması....20
Tablo 9. En az ayrıcalığın üç boyutu....21
Tablo 10. Katmanlı tasarımda güvenlik kontrollerinin katkıları....25
Tablo 11. Veritabanı parolasını yenilerken ele alınacak adımlar....28
Tablo 12. Anahtar işlemleri ve veriye erişim üzerindeki etkileri. 31
Tablo 13. Rapor paylaşım senaryosunda gereksinimler ve güvenlik kararları. 33

Şekiller Listesi

Şekil 1. Kullanıcıdan uygulamaya ve uygulamadan depolamaya geçişte farklı erişim denetimleri uygulanır. 7
Şekil 2. Korunan bir kaynağa erişimde kimlik doğrulama ve yetkilendirme kararlarının ayrılması. 13
Şekil 3. Kullanıcının kurumsal kimliğiyle proje teslim hizmetine erişmesine ilişkin basitleştirilmiş federasyon akışı. 16
Şekil 4. Uygulamanın kendi kimliğiyle veri hizmetine eriştiği bir tasarımda yönetim, kullanıcı ve uygulama yetkilerinin ayrılması. 23
Şekil 5. Erişim bağlamı, politika kararı, uygulama denetimi ve kaynak izinlerinin birlikte kullanıldığı kavramsal güvenlik akışı. 26
Şekil 6. Uygulamanın kendi kimliğiyle gerekli sırrı alması ve bu bilgiyi veritabanına erişimde kullanması. 27
Şekil 7. Uygulama tarafında zarf şifreleme örneği: Veri DEK ile, DEK ise KMS içinde korunan KEK ile şifrelenir. 30
Şekil 8. Rapor paylaşım uygulamasında kullanıcı erişimi, uygulama kimliği, sır yönetimi ve depolama şifrelemesinin birlikte kullanılması. 32

1. Dersin Amacı ve Öğrenme Çıktıları

1.1. Haftanın Amacı ve Bulutta Güvenliğin Yeri

Bulut ortamında bir uygulamanın çalışıyor olması, kaynaklarının ve verilerinin güvenli biçimde kullanıldığı anlamına gelmez. Kullanıcıların yalnız yetkili oldukları verilere ulaşması, uygulamaların görevleri için gerekli izinlerle çalışması ve hassas bilgilerin korunması da mimarinin temel gereksinimleridir. Bu nedenle güvenlik; işlem, ağ, depolama ve uygulama bileşenleriyle birlikte tasarlanmalıdır.

Bulut hizmetlerinde güvenlik görevleri, hizmet sağlayıcı ile müşteri arasında paylaşılır. *Shared Responsibility (paylaşılan sorumluluk)* olarak adlandırılan bu yaklaşımda görev dağılımı, kullanılan hizmetin türüne göre değişir. Sağlayıcının fiziksel altyapıyı veya yönetilen bir hizmetin yazılımını koruması, müşterinin kullanıcı izinlerini ve veri paylaşımını doğru yapılandırma sorumluluğunu ortadan kaldırmaz [1], [2].

Bu haftanın temel amacı, bir bulut uygulamasında kimin, hangi kaynağa, hangi işlemi yapmak üzere ve hangi koşullarda erişebileceğini belirleyebilmektir. *Identity and Access Management (kimlik ve erişim yönetimi, IAM)* bu kararların yönetilmesini sağlar. Bunun yanında, uygulamaların kullandığı parolalar ve erişim anahtarları gibi sırların korunması, verilerin şifrelenmesi ve şifreleme anahtarlarının uygun yetkilerle yönetilmesi gerekir.

Örneğin bir üniversitenin proje teslim sisteminde öğrencinin kendi raporunu yükleyebilmesi, başka öğrencilerin raporlarını okuyabilmesini gerektirmez. Raporları işleyen uygulamanın dosyalara erişebilmesi de kullanıcıların yetkilerini değiştirebilmesini gerektirmez. Böyle bir sistemde kullanıcı, uygulama ve yönetici için farklı erişim sınırları oluşturulmalıdır. Verilerin şifrelenmesi ise bu sınırların doğru belirlenmesiyle birlikte ele alınmalıdır.

Hafta boyunca güvenlik, bu tür somut erişim ve veri koruma gereksinimleri üzerinden incelenecektir. Hedef, güvenlik hizmetlerinin adlarını ezberlemekten çok; uygun kontrolü seçebilmek, kontrolün hangi riski azalttığını açıklayabilmek ve beklenen erişim sınırlarının uygulandığını doğrulayabilmektir.

1.2. Öğrenme Çıktıları

Bu haftayı tamamlayan öğrencinin aşağıdaki yeterlilikleri kazanması beklenmektedir:

1. Bulut hizmetlerinde sağlayıcının ve müşterinin güvenlik sorumluluklarını ayırt eder; farklı hizmet modellerinde bu sorumlulukların nasıl değiştiğini örneklerle açıklar.
2. Kimlik, kimlik bilgisi, kimlik doğrulama ve yetkilendirme kavramlarını birbirinden ayırır; bir bulut kaynağına erişim sürecindeki işlevlerini açıklar.
3. İnsan ve uygulama kimlikleri için uygun koruma yöntemlerini seçer; çok etmenli doğrulama, federasyon ve kısa ömürlü kimlik bilgilerinin kullanım amacını gerekçelendirir.
4. Bir uygulamanın erişim gereksinimlerinden hareketle rol ve nitelik tabanlı erişim kuralları oluşturur; işlem, kaynak ve süre açısından gereğinden geniş izinleri belirler.
5. En az ayrıcalık ve sıfır güven ilkelerini bir bulut senaryosuna uygular; ağ denetimi, bulut kaynak izinleri ve uygulama içi erişim kontrollerinin birbirini nasıl tamamladığını açıklar.

6. Parola ve erişim anahtarı gibi sırların güvenli saklanması, uygulamaya sağlanması, yenilenmesi ve iptal edilmesi için uygun bir yaşam döngüsü tasarlar.
7. Aktarımda ve depolamada şifrelemenin amaçlarını açıklar; veri anahtarı, anahtar yönetim hizmeti ve anahtar yaşam döngüsü arasındaki ilişkiyi değerlendirir.
8. Bütünleşik bir bulut senaryosunda güvenlik kontrollerini gerekçelendirir; izin verilmesi ve reddedilmesi gereken erişimleri belirleyerek tasarımın güvenlik gereksinimlerini karşılayıp karşılamadığını değerlendirir.

2. Bulutta Güvenlik Hedefleri ve Sorumluluk Paylaşımı

Bir bulut uygulamasının güvenliğini tasarlarken önce hangi verilerin ve hizmetlerin korunacağı, bunların hangi tehditlerle karşılaşabileceği ve güvenlik görevlerinin kim tarafından yerine getirileceği belirlenmelidir. Bu bölümde güvenliğin temel hedefleri, bulut ortamındaki başlıca riskler ve kullanılan hizmet modeline göre sağlayıcı ile müşterinin sorumlulukları ele alınacaktır.

2.1. Gizlilik, Bütünlük ve Kullanılabilirlik

Bilgi güvenliği, verilerin ve bu verileri işleyen sistemlerin üç temel hedef doğrultusunda korunmasını amaçlar: Confidentiality (gizlilik), Integrity (bütünlük) ve Availability (kullanılabilirlik). İngilizce karşılıklarının baş harfleriyle CIA üçlüsü olarak adlandırılan bu hedefler, bir güvenlik olayının etkisini değerlendirmek ve uygun kontrolleri seçmek için temel oluşturur [3].

Gizlilik

Gizlilik, bilginin yalnız erişim hakkı bulunan kişiler ve uygulamalar tarafından görülebilmesidir. Bulut ortamında bir verinin depolanıyor olması kadar, kimlerle ve hangi yollarla paylaşıldığı da önemlidir. Yanlış yapılandırılmış bir depolama alanı, gereğinden geniş kullanıcı izinleri veya ele geçirilmiş bir uygulama kimliği gizlilik ihlaline neden olabilir.

Örneğin üniversitenin proje teslim sisteminde bir öğrencinin başka bir öğrencinin raporunu izinsiz okuyabilmesi gizlilik ihlalidir. Bu durumda sistem çalışmaya devam edebilir ve dosyanın içeriği değişmemiş olabilir; ancak veri yetkisiz bir kişiye açıklanmıştır.

Gizliliği destekleyen kontroller arasında kimlik doğrulama, erişim izinlerinin sınırlandırılması ve şifreleme bulunur. Bu kontroller birbirini tamamlar; şifreleme, doğru yetkilendirmenin yerine geçmez.

Bütünlük

Bütünlük, verilerin ve sistem yapılandırmalarının yetkisiz veya uygunsuz biçimde değiştirilmesine ya da yok edilmesine karşı korunmasıdır. Amaç, kullanılan bilginin güvenilirliğini korumaktır. Bulutta yalnız dosya içerikleri değil; erişim politikaları, uygulama ayarları ve veritabanı kayıtları da bütünlük açısından değerlendirilmelidir.

Proje teslim sisteminde bir öğrencinin başka bir öğrencinin raporunu değiştirmesi veya değerlendirme puanlarını yetkisiz biçimde güncellemesi bütünlük ihlalidir. Benzer şekilde, uygulamanın erişim politikasının değiştirilerek daha geniş izinler verilmesi de sistem yapılandırmasının bütünlüğünü etkiler.

Bütünlüğü desteklemek için yazma ve silme izinleri sınırlandırılır, kritik değişiklikler denetlenir ve gerektiğinde verinin değiştirilip değiştirilmediğini belirleyen kriptografik doğrulama mekanizmaları kullanılır. Bir değişikliğin kayda alınması, değişikliği engellemekle aynı işlevi görmez; ancak olayın incelenmesine yardımcı olur.

Kullanılabilirlik

Kullanılabilirlik, yetkili kullanıcıların verilere ve hizmetlere ihtiyaç duyduklarında zamanında ve güvenilir biçimde erişebilmesidir. Hizmetin çalışmasını engelleyen saldırılar kadar hatalı yapılandırmalar, yanlışlıkla silinen kaynaklar veya erişilemeyen şifreleme anahtarları da bu hedefi etkileyebilir.

Örneğin proje teslim sisteminin son teslim saatinde erişilemez olması kullanılabilirlik sorunudur. Dosyalar korunuyor olsa bile öğrenciler rapor yükleyemiyorsa hizmet amacını yerine getiremez. Benzer biçimde, şifreleme anahtarının yanlışlıkla silinmesi dosyalar depoda durduğu hâlde içeriklerine erişilememesine yol açabilir.

Üç Hedefin Birlikte Değerlendirilmesi

Bir güvenlik olayı birden fazla hedefi etkileyebilir. Bir raporun yetkisiz silinmesi hem bütünlüğü hem kullanılabilirliği bozabilir. Buna karşılık, bir hizmetin herkese kapatılması gizliliği koruyor gibi görünse de yetkili kullanıcıların erişimini de engelliyorsa uygun bir çözüm değildir.

Bu nedenle bulut güvenliği tasarımında her kontrol için şu soru sorulmalıdır: Bu kontrol hangi güvenlik hedefini destekliyor ve diğer hedefleri nasıl etkiliyor? Amaç, veriyi korurken yetkili kullanımın da sürdürülebilmesini sağlamaktır.

2.2. Varlıklar, Tehditler ve Güven Sınırları

Bir bulut sisteminde güvenlik kontrollerini seçmeden önce üç soru yanıtlanmalıdır: Neyi koruyoruz? Ne ters gidebilir? Hangi noktada farklı bir kimlik veya yetki alanına geçiyoruz? Bu sorular, güvenlik gereksinimlerini uygulamanın mimarisiyle ilişkilendirmeyi sağlar.

Korunacak Varlıkların Belirlenmesi

Asset (varlık), sistem açısından değer taşıyan ve korunması gereken veri, kaynak veya yetenektir. Bulut ortamında varlıklar yalnız kullanıcı dosyalarından oluşmaz. Veritabanı kayıtları, uygulama kimlikleri, parolalar, şifreleme anahtarları, erişim politikaları ve hizmetin çalışmasını sağlayan kaynaklar da bu kapsamda değerlendirilir.

Üniversite proje teslim sisteminde öğrenci raporları ve değerlendirme puanları doğrudan korunacak verilerdir. Ancak raporlara erişebilen uygulama kimliği de önemli bir varlıktır. Bu kimliğin ele geçirilmesi, saldırganın uygulamaya tanınan izinleri kullanmasına yol açabilir. Benzer şekilde, erişim politikalarını değiştirme yetkisi, başka kaynaklara erişim elde etmek için kullanılabileceğinden ayrıca korunmalıdır.

Tehdit, Güvenlik Açığı ve Risk Ayrımı

Threat (tehdit), bir varlığın güvenliğini olumsuz etkileyebilecek olay veya durumdur. *Vulnerability (güvenlik açığı)*, böyle bir olayın gerçekleşmesine imkân verebilen ya da etkisini artırabilen

zayıflıktır. *Risk (risk)* ise olumsuz olayın gerçekleşme olasılığı ve doğuracağı etki birlikte değerlendirilerek belirlenir [4].

Örneğin öğrenci raporlarının yetkisiz kişilerce okunması bir tehdit olayıdır. Depolama alanının yanlışlıkla herkese açık bırakılması bu olaya imkân veren bir güvenlik açığıdır. Açığın oluşturduğu risk; dosyaların hassasiyetine, erişimin ne kadar kolay olduğuna ve açıklanmanın doğuracağı sonuçlara bağlıdır.

Tehditler yalnız kötü niyetli saldırılardan kaynaklanmaz. Yetkili bir yöneticinin yanlış kaynağı silmesi, uygulama güncellemesinin erişim ayarlarını bozması veya bir şifreleme anahtarının yanlışlıkla devre dışı bırakılması da güvenliği etkileyebilir. Bu nedenle değerlendirmede hem kasıtlı eylemler hem insan hataları ve teknik arızalar dikkate alınmalıdır [4].

Tablo 1. Bulut sisteminde örnek tehditler ve uygun güvenlik kontrolleri

Korunacak Varlık	Tehdit Olayı	İlgili Zayıflık	Riski Azaltabilecek Kontrol
Öğrenci raporları	Başka bir öğrencinin raporu okuması	Dosya sahipliğinin denetlenmemesi	Her dosya isteğinde kullanıcı ve sahiplik kontrolü
Değerlendirme puanları	Puanların yetkisiz değiştirilmesi	Gereğinden geniş yazma izinleri	Göreve ve kaynak kapsamına göre yetkilendirme
Uygulama kimliği	Ele geçirilen kimlikle başka kaynaklara erişilmesi	Ortak kimlik ve geniş izinler	Uygulamaya özel kimlik ve sınırlı kaynak erişimi
Veritabanı parolası	Parolanın kaynak koddan veya imajdan sızması	Sırrın uygulamayla birlikte saklanması	Merkezi sır yönetimi ve kontrollü dağıtım
Şifreleme anahtarı	Anahtarın yanlışlıkla silinmesi	Silme yetkisinin gereksiz kişilere verilmesi	Anahtar yönetiminde görev ayrılığı ve silme korumaları

Tablodaki kontroller belirli zayıflıkları ve saldırı yollarını ele alır. Kontrol seçimi, korunacak varlık ve ilgili tehditle ilişkilendirilmelidir.

Güven Sınırlarının Belirlenmesi

Trust Boundary (güven sınırı), farklı güven varsayımlarına, kimliklere veya yetki düzeylerine sahip alanlar arasındaki geçişi ifade eder. Böyle bir geçişte, karşı taraftan gelen isteğin veya bilginin hangi denetimlerden geçirilmesi gerektiği belirlenmelidir. Güven sınırı yalnız fiziksel ağ sınırı değildir; kullanıcı ile uygulama veya uygulama ile yönetilen depolama hizmeti arasında da bulunabilir [5].

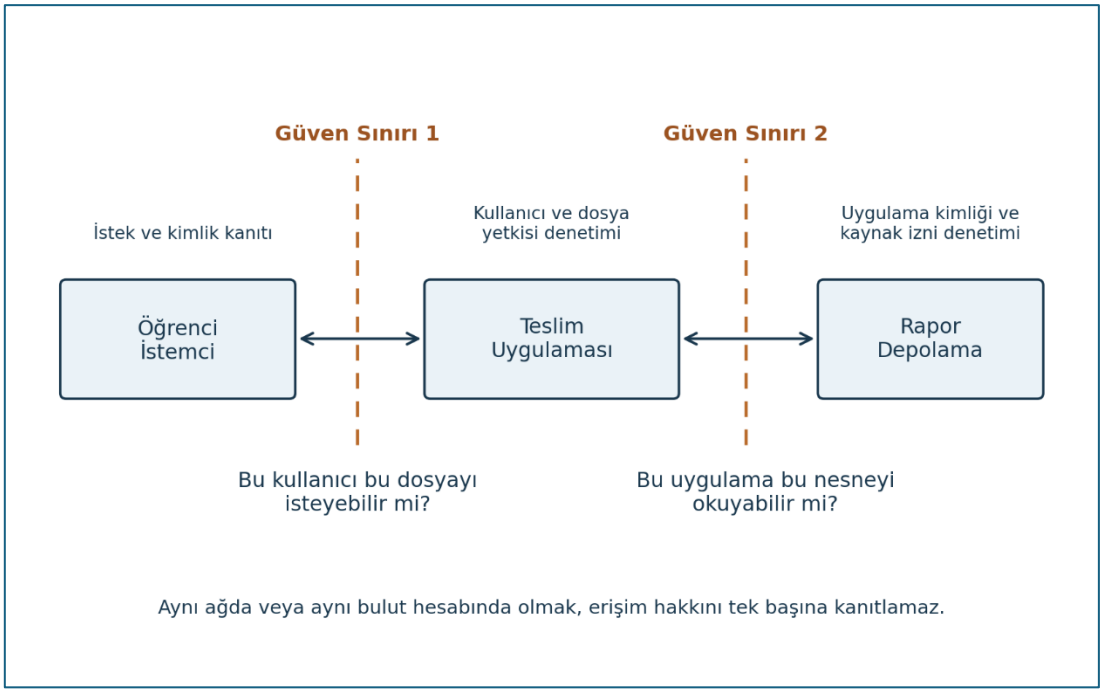
Şekil 1'de proje teslim sistemindeki iki güven sınırı gösterilmektedir.

Şekil 1'de kullanıcı–uygulama ve uygulama–depolama geçişleri ayrı güven sınırlarıdır. İlkinde kullanıcının hedef rapora erişim hakkı, ikincisinde uygulama kimliğinin depolama izni denetlenir. Her sınır için isteği yapan taraf ve uygulanacak kontrol ayrı belirlenmelidir.

Güvenlik Kontrolünün Tehditle Eşleştirilmesi

Güvenlik değerlendirmesi; varlığın belirlenmesi, olası olayın tanımlanması, ilgili zayıflığın bulunması ve uygun kontrolün seçilmesiyle ilerler. Son adımda kontrolün beklenen sınırı gerçekten uyguladığı doğrulanır. Bu yaklaşım, *Threat Modeling (tehdit modelleme)* çalışmasının temelini oluşturur [5].

Örneğin "başka öğrencinin raporunu okuma" tehdidine karşı dosya sahipliği denetimi eklenmişse, yalnız öğrencinin kendi raporunu okuyabildiği gösterilmemelidir. Başka bir öğrencinin raporunu istediğinde erişimin reddedildiği de sınanmalıdır.



Şekil 1. Kullanıcıdan uygulamaya ve uygulamadan depolamaya geçişte farklı erişim denetimleri uygulanır.

2.3. Hizmet Modellerine Göre Sağlayıcı ve Müşteri Görevleri

Bulut ortamında güvenlik görevlerinin hangi tarafa ait olduğu, kullanılan hizmetin kapsamına göre değişir. Sağlayıcı bazı altyapı ve yazılım katmanlarını işletirken müşteri, kendi verilerinin kullanımını, kullanıcı erişimlerini ve yönetebildiği bileşenlerin güvenlik ayarlarını düzenler. Bu nedenle sorumluluk paylaşımı, her hizmet için ayrı değerlendirilmelidir [1], [2].

Temel ilke şudur: Bir katmanın işletiminin sağlayıcıya devredilmesi, o hizmetin müşteri tarafından güvenli kullanılmasına ilişkin görevleri ortadan kaldırmaz.

Altyapı Hizmetlerinde Sorumluluklar

Infrastructure as a Service (hizmet olarak altyapı, IaaS) modelinde müşteri; sanal makineler, depolama ve ağ kaynakları üzerinde geniş bir yapılandırma alanına sahiptir. Sağlayıcı fiziksel tesisleri, temel donanımı ve sanallaştırma altyapısını yönetirken müşteri genellikle sanal makinenin işletim sistemini, kurduğu yazılımları ve bunların güvenlik ayarlarını yönetir [1].

Örneğin bir sanal makinenin işletim sistemi güncellemelerinin uygulanması, gereksiz hizmetlerin kapatılması ve uygulamanın hangi bağlantıları kabul edeceğinin belirlenmesi müşterinin görevleri arasındadır. Sağlayıcının veri merkezini fiziksel olarak koruması, müşterinin güncel olmayan işletim sisteminden kaynaklanan açığı gidermez.

Platform Hizmetlerinde Sorumluluklar

Platform as a Service (hizmet olarak platform, PaaS) modelinde sağlayıcı, uygulamanın üzerinde çalıştığı işletim sistemi ve çalışma ortamı gibi daha fazla katmanı yönetir. Müşteri ise geliştirdiği uygulamanın güvenliğinden, uygulama yapılandırmasından, erişim izinlerinden ve verilerinin uygun biçimde kullanılmasından sorumlu olmaya devam eder [2], [6].

Örneğin yönetilen bir uygulama platformunda işletim sisteminin yamalanması sağlayıcının görevi olabilir. Ancak uygulamanın bir öğrencinin başka öğrencilerin raporlarını okumasına izin vermesi, uygulama düzeyinde ele alınması gereken bir sorundur. Platformun güncel tutulması, hatalı iş kurallarını veya eksik yetkilendirme kontrollerini kendiliğinden düzeltmez.

Yazılım Hizmetlerinde Sorumluluklar

Software as a Service (hizmet olarak yazılım, SaaS) modelinde hazır bir uygulama kullanılır. Sağlayıcı uygulama yazılımını ve onu çalıştıran altyapıyı işletir. Müşteri ise hizmetin sunduğu yönetim seçenekleri kapsamında kullanıcı hesaplarını, rol atamalarını, paylaşım tercihlerini ve erişimlerin kaldırılmasını yönetir [2], [6].

Örneğin bulut tabanlı bir belge paylaşım hizmetinde uygulamanın güncellenmesi sağlayıcı tarafından yapılabilir. Buna karşılık kurum içi bir belgenin herkese açık bağlantıyla paylaşılması, müşterinin kullanım ve yapılandırma kararlarıyla ilgilidir. Kurumdan ayrılan bir çalışanın erişiminin kaldırılması da ayrıca ele alınmalıdır.

Tablo 2. Hizmet Modellerine Göre Genel Güvenlik Sorumlulukları

Güvenlik Görevi	IaaS	PaaS	SaaS
Fiziksel tesis ve donanımın korunması	Sağlayıcı	Sağlayıcı	Sağlayıcı
Temel sanallaştırma altyapısının güvenliği	Sağlayıcı	Sağlayıcı	Sağlayıcı
İş yükünün işletim sistemi ve çalışma ortamının bakımı	Genellikle müşteri	Hizmetin yönettiği katmanlarda sağlayıcı	Sağlayıcı
Uygulama yazılımının güvenliği	Müşterinin kurduğu uygulamada müşteri	Müşterinin geliştirdiği uygulamada müşteri	Sunulan uygulamada sağlayıcı
Kullanıcı ve uygulama erişimlerinin yapılandırılması	Müşteri	Müşteri	Sunulan seçenekler kapsamında müşteri
Verilerin sınıflandırılması ve kimlerle paylaşılacağının belirlenmesi	Müşteri	Müşteri	Müşteri
Şifreleme ve anahtar yönetimi	Kullanılan hizmete ve seçilen yönetim modeline göre paylaşılır	Kullanılan hizmete ve seçilen yönetim modeline göre paylaşılır	Hizmetin sunduğu olanaklara göre paylaşılır

Tablo 2 genel bir karşılaştırmadır. Aynı model altında sunulan hizmetlerin yönetim sınırları farklı olabilir. Ayrıca sağlayıcının erişim denetimi mekanizmasını güvenli işletmesi ile müşterinin bu mekanizmada doğru izinleri tanımlaması birbirini tamamlayan, farklı görevlerdir. Gerçek görev dağılımı hizmetin resmî belgelerinden ve sözleşme kapsamından doğrulanmalıdır [1], [2], [6].

Proje teslim uygulamasının sanal makineden yönetilen platforma taşınması, işletim sistemi bakımını sağlayıcıya devredebilir; ancak öğrencilerin yalnız yetkili oldukları raporlara erişmesini sağlama sorumluluğunu ortadan kaldırmaz. Hazır bir yazılım hizmetinde de kurumun kullanıcı rolleri ve paylaşım ayarlarını doğru yönetmesi gerekir. Bu nedenle her hizmet için sağlayıcının yönettiği katmanlarla müşterinin yapılandırıp denetlemesi gereken güvenlik görevleri birlikte belirlenmelidir [1], [2], [6].

2.4. Yanlış Yapılandırma ve Çok Kiracılı Ortamda İzolasyon

Bir bulut hizmetinin güvenlik özellikleri sunması, bu özelliklerin uygulamanın gereksinimlerine uygun kullanıldığı anlamına gelmez. Kaynakların kimlere açık olduğu, uygulamaların hangi izinlerle çalıştığı ve paylaşılan bileşenlerde verilerin nasıl ayrıldığı doğru yapılandırılmalıdır.

Yanlış Yapılandırmadan Kaynaklanan Açıklar

Security Misconfiguration (güvenlik açısından yanlış yapılandırma), sistemin veya hizmetin güvenlik ayarlarının eksik ya da uygunsuz olmasıdır. Gereksiz hizmetlerin açık bırakılması, varsayılan hesapların kullanılmaya devam edilmesi ve hata mesajlarında hassas ayrıntıların gösterilmesi bu duruma örnektir [7].

Bulut ortamında yanlış yapılandırma farklı katmanlarda ortaya çıkabilir:

- Yalnız uygulamanın erişmesi gereken bir depolama alanının herkese açılması.
- Bir uygulamaya, görevi yalnız dosya okumak olduğu hâlde kaynakları silme veya kullanıcı yetkilerini değiştirme izni verilmesi.
- Test amacıyla açılan bir yönetim arayüzünün üretim ortamında erişilebilir bırakılması.
- Uygulama hata çıktılarında parola veya bağlantı bilgisi gösterilmesi.

Bu durumlarda kullanılan yazılım güncel olabilir; açık, hizmetin kullanım biçiminden kaynaklanır. *Hardening (güvenlik sıkılaştırması)* kapsamında gereksiz bileşenler kapatılır, izinler daraltılır ve yapılandırmalar güvenlik gereksinimlerine göre düzenlenir. Ayarların doğruluğu, değişikliklerden sonra da kontrol edilmelidir [7].

Çok Kiracılık ve İzolasyon Gereksinimi

Multi-tenancy (çok kiracılık), bir hizmetin altyapı veya uygulama bileşenlerini birden fazla müşteri için paylaşmasıdır. *Tenant (kiracı)*, bu hizmet içinde verileri ve erişim hakları ayrı yönetilen müşteri veya kuruluşu ifade eder. Bir kiracının birden fazla kullanıcısı bulunabilir.

Paylaşım fiziksel sunucu düzeyinde olabileceği gibi uygulama veya veritabanı düzeyinde de gerçekleşebilir. *Isolation (izolasyon)*, bu paylaşım sırasında bir kiracının başka bir kiracının verilerine ve kaynaklarına yetkisiz erişmesini veya işlemlerini olumsuz etkilemesini sınırlayan ayrımdır [8].

Altyapıdaki ayrım ile uygulamadaki ayrım farklı katmanlardır. Ayrı sanal makineler kullanılması, ortak bir uygulamanın hatalı yetkilendirme yapmasını engellemez. Ortak veritabanı kullanılması ise uygun erişim kontrolleriyle desteklenmesi gereken mantıksal bir ayrım gerektirir.

Uygulama Örneği

Proje teslim hizmetinin iki farklı üniversite tarafından kullanıldığını düşünelim. Her üniversite ayrı bir kiracıdır. İki üniversitenin raporları ortak bir veritabanında tutuluyor ve her kayıtta üniversiteyi belirten bir kiracı kimliği bulunuyor olsun.

Uygulama, kullanıcının istekte gönderdiği kiracı kimliğini denetlemeden kabul ederse kullanıcı bu değeri değiştirerek diğer üniversitenin kayıtlarını isteyebilir. Bu nedenle seçilen kiracı ile doğrulanmış kullanıcı arasında yetkili bir ilişki bulunduğu sunucu tarafında kontrol edilmelidir [8].

Ayrıca yalnız kiracı üyeliğini doğrulamak yeterli değildir. Aynı üniversitedeki bir öğrencinin başka öğrencilerin raporlarını okuyup okuyamayacağı da ayrıca değerlendirilmelidir. Böylece iki farklı sınır ortaya çıkar: kiracılar arasındaki ayrım ve aynı kiracı içindeki kullanıcı yetkileri.

İzolasyonun Doğrulanması

İzolasyon; işlem kaynakları, ağ bağlantıları, uygulama yetkilendirmesi ve veri erişimi birlikte değerlendirilerek sağlanır. Dosyaların farklı klasörlere konulması veya kayıtlara kiracı kimliği eklenmesi, bu ayrım erişim kararlarında uygulanmıyorsa yeterli değildir [8].

Örnek sistemde doğrulama, bir üniversitenin kullanıcısının kendi yetkili raporuna erişebilmesini ve diğer üniversitenin raporuna erişememesini göstermelidir. Aynı kiracı içindeki kullanıcı sınırları da ayrıca sınanmalıdır. Amaç, mimaride tanımlanan ayrımın gerçek istekler karşısında korunduğunu kanıtlamaktır.

3. Kimlik Yönetimi ve Kimlik Doğrulama

Bulut kaynaklarına güvenli erişim sağlamak için isteği yapan tarafın kim olduğu belirlenmeli ve bu kimliği hangi kanıtlarla doğruladığı değerlendirilmelidir. İstekte bulunan taraf bir öğrenci veya sistem yöneticisi olabileceği gibi dosya işleyen bir uygulama da olabilir. İnsanların ve uygulamaların farklı çalışma biçimleri, kimliklerinin korunmasında farklı yöntemler kullanılmasını gerektirir.

IAM kapsamında kimliklerin oluşturulması, uygun doğrulama yöntemleriyle kullanılması, görev değişikliklerinde güncellenmesi ve ihtiyaç sona erdiğinde erişimlerinin kaldırılması birlikte ele alınır. Bu bölümde kimlik ile kimlik bilgisi arasındaki fark açıklanacak; kimlik doğrulamanın yetkilendirmeden ayrıldığı noktalar, insan ve uygulama kimliklerinin korunması ve kimlik yaşam döngüsü incelenecektir.

3.1. Kimlik ve Kimlik Bilgisi Ayrımı

Bir bulut sistemine erişen tarafın sistemde nasıl temsil edildiği ile bu tarafın kimliğini nasıl kanıtladığı farklı konulardır. Kullanıcı hesabı, kullanıcı adı ve parola günlük kullanımda birbirinin yerine söylense de güvenlik tasarımında bu kavramların ayrılması gerekir.

Kimlik ve Tanımlayıcı

Digital Identity (dijital kimlik), bir tarafın belirli bir sistem veya hizmet içindeki temsilidir. Bir kişi farklı sistemlerde farklı dijital kimliklere sahip olabilir [9]. Bulut ortamında yalnız insanlar değil, uygulamalar ve servisler de kendilerine ait kimliklerle işlem yapabilir.

Identifier (tanımlayıcı) ise sistemin ilgili kimliği ayırt etmek için kullandığı değerdir. Kullanıcı adı, öğrenci numarası veya uygulama hesabının benzersiz adı birer tanımlayıcı olabilir. Ancak bir tanımlayıcıyı bilmek, o kimliği kullanma hakkını kanıtlamaz.

Örneğin proje teslim sistemindeki bir öğrencinin kullanıcı adını bilmek, o öğrencinin hesabına giriş yapabilmek için yeterli olmamalıdır. Kullanıcı adı hangi hesap için giriş yapılmak istendiğini belirtir; sistem ayrıca uygun bir kimlik kanıtı arar.

Kimlik Bilgisi

Bulut hizmetlerinde *Credential (kimlik bilgisi)* terimi; parola, erişim anahtarı veya geçici güvenlik bilgileri gibi kimlik doğrulamada kullanılan bilgiler için yaygın biçimde kullanılır. Bunların türü ve

kullanım biçimi, insanın etkileşimli giriş yapmasına veya bir uygulamanın program aracılığıyla erişmesine göre değişebilir [10].

Parolayla girişte kullanıcı, hesapla ilişkilendirilmiş gizli bilgiyi bildiğini gösterir. Kriptografik anahtar kullanılan yöntemlerde ise ilgili özel anahtara sahip olunduğu bir işlemle kanıtlanabilir; özel anahtarın kendisinin karşı tarafa gönderilmesi gerekmez. *Authenticator (doğrulayıcı)*, kimliği kanıtlamak için kullanılan parola veya kriptografik anahtar içeren araç gibi unsurları ifade eder [9].

Bu ayrımda tanımlayıcı "Hangi kimlik?" sorusuna, doğrulamada kullanılan bilgi veya araç ise "Bu kimliği kullandığını nasıl kanıtlıyor?" sorusuna karşılık gelir.

Tablo 3. Kimlik, Tanımlayıcı ve Doğrulamada kullanılan bilgi örnekleri

Sistemdeki Kimlik	Tanımlayıcı Örneği	Doğrulamada Kullanılabilecek Bilgi veya Araç
Öğrenci hesabı	Öğrenci numarası veya kullanıcı adı	Parola veya hesaba bağlı bir doğrulayıcı
Öğretim elemanı hesabı	Kurumsal kullanıcı adı	Parola ve ek doğrulama aracı
Rapor işleme uygulaması	Uygulamaya ait servis kimliğinin adı	Platformun sağladığı geçici güvenlik bilgileri
Dış sistemle iletişim kuran servis	Servis hesabının benzersiz tanımlayıcısı	Desteklenen yönteme göre kriptografik anahtar veya geçici güvenlik bilgileri

Tablo 3'teki yöntemler örnektir; her kimlik türünün yalnız tek bir doğrulama yöntemi kullanması gerekmez. Uygun yöntem, hizmetin desteğine ve güvenlik gereksinimlerine göre seçilir.

Kimlik Bilgisinin Değişmesi Kimliğin Değişmesi Değildir

Bir öğrenci parolasını değiştirdiğinde genellikle aynı hesabı kullanmaya devam eder. Hesabın sahibi, dosyaları ve erişim izinleri bu işlem nedeniyle kendiliğinden değişmez. Benzer şekilde, bir uygulamanın kullandığı geçici güvenlik bilgilerinin süresi dolup yenileri alındığında uygulama aynı kimlikle çalışmayı sürdürebilir [10].

Örneğin rapor işleme servisinin yalnız belirli bir proje alanını okuma izni varsa, kimlik bilgilerinin yenilenmesi bu izni otomatik olarak genişletmez. Kimliği kanıtlayan bilgilerin yönetimi ile kimliğe verilen izinlerin yönetimi ayrı ele alınmalıdır.

Kimlik bilgilerinin ele geçirilmesi, saldırganın meşru kimlik adına işlem yapmasına yol açabilir. Bu nedenle gizli bilgiler korunmalı; sızan veya kaybolan doğrulama araçları uygun biçimde geçersiz kılınmalıdır. Yalnız kullanıcı adını değiştirmek veya uygulamaya yeni bir ad vermek, ele geçirilmiş kimlik bilgisini kendiliğinden geçersiz kılmaz.

3.2. Kimlik Doğrulama ve Yetkilendirme Ayrımı

Bir kaynağa erişim isteği değerlendirilirken iki farklı karar verilir: İsteği yapan tarafın kimliği doğrulanır ve bu tarafın istenen işlemi yapmaya yetkili olup olmadığı belirlenir. Bu kararlar birbiriyle ilişkili olsa da aynı anlama gelmez.

Kimlik Doğrulama

Authentication (kimlik doğrulama), bir tarafın iddia ettiği kimliği uygun kanıtlarla doğrulama sürecidir. Kullanıcının parola veya hesabına bağlı başka bir doğrulayıcı kullanması bu sürecin parçasıdır [9].

Örneğin bir öğrencinin proje teslim sistemine giriş yapması sırasında sistem, sunulan kimlik kanıtını değerlendirir. Başarılı sonuç, isteğin ilgili öğrenci hesabıyla ilişkilendirilmesini sağlar. Ancak öğrencinin hangi raporları okuyabileceğini veya hangi dosyaları silebileceğini tek başına belirlemez.

Yetkilendirme

Authorization (yetkilendirme), belirli bir tarafın belirli bir kaynak üzerinde istenen işlemi yapmasına izin verilip verilmeyeceğinin değerlendirilmesidir. Dolayısıyla karar yalnız kimliğe değil, hedef kaynağa ve istenen işleme de bağlıdır [11].

Proje teslim sisteminde öğrencinin kendi raporunu okumasına izin verilirken başka öğrencinin raporunu okuması reddedilebilir. Aynı öğrenci, kendi raporunu okuyabilmesine rağmen değerlendirme puanını değiştiremez. Her iki durumda da kimlik aynıdır; değişen, kaynak veya işlemdir.

Tablo 4. Doğrulanmış bir kimlik için farklı yetkilendirme kararları

İstekte Bulunan	İstenen İşlem ve Kaynak	Kimlik Doğrulama Durumu	Yetkilendirme Sonucu
Öğrenci A	Kendi raporunu okuma	Başarılı	İzin verilir
Öğrenci A	Öğrenci B'nin raporunu okuma	Başarılı	Reddedilir
Öğrenci A	Kendi değerlendirme puanını değiştirme	Başarılı	Reddedilir
Öğrenci A	Herkese açık ders duyurusunu okuma	Gerekli olmayabilir	Kamuya açık erişim kuralıyla izin verilir

Tablo 4, örnek sistemin erişim kurallarını göstermektedir. Başarılı kimlik doğrulama, bütün kaynaklara erişim hakkı vermez. Ayrıca herkese açık bir duyuru gibi kaynaklara erişim için kullanıcı kimliğinin doğrulanması zorunlu olmayabilir [11].

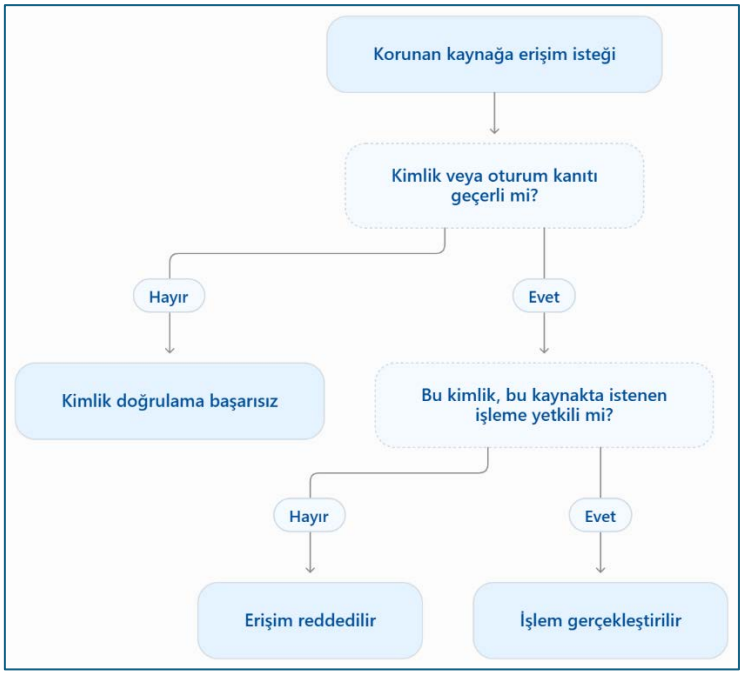
Denetimin Doğru Yerde Yapılması

Yetkilendirme, isteği işleyen güvenilir sunucu tarafında uygulanmalıdır. Kullanıcı arayüzünde bir düğmenin gizlenmesi, ilgili işlemi engellemez; kullanıcı aynı isteği doğrudan gönderebilir. Bu nedenle sunucu, arayüzdeki kısıtlamalardan bağımsız olarak kullanıcının hedef kaynak üzerindeki işlem yetkisini denetlemelidir [11].

Her İstekte Yetkinin Değerlendirilmesi

Korunan kaynaklara yönelik her istekte, doğrulanmış kimliğin hedef kaynak üzerinde istenen işlemi yapmaya yetkili olup olmadığı değerlendirilmelidir. Sistem, kullanıcıyı geçerli oturumu üzerinden tanıyabilir; her işlemde yeniden parola girilmesi gerekmez. Ancak oturumun geçerli olması, farklı kaynak ve işlemler için yetkilendirme denetimini ortadan kaldırmaz [11].

Aynı ayrım uygulama kimlikleri için de geçerlidir. Rapor işleme servisinin kimliğinin doğrulanması, servisin bütün depolama alanlarını okuyabileceği veya erişim politikalarını değiştirebileceği anlamına gelmez. Servisin yetkileri, gerçekleştireceği görevlerle sınırlandırılmalıdır.



Şekil 2. Korunan bir kaynağa erişimde kimlik doğrulama ve yetkilendirme kararlarının ayrılması.

3.3. İnsan Kimlikleri ve Çok Etmenli Doğrulama

Bulut kaynaklarını kullanan taraflar, görevlerine uygun kişisel hesaplarla işlem yapmalıdır. Bir hesabın birden fazla kişi tarafından paylaşılması, işlemlerin kimin tarafından gerçekleştirildiğini belirlemeyi ve kişiye özgü erişimleri kaldırmayı güçleştirir.

İnsan kimliklerinin korunmasında temel sorunlardan biri, parolanın ele geçirilmesidir. Kullanıcı güçlü bir parola seçmiş olsa bile sahte bir giriş sayfasına bu parolayı yazabilir. Bu nedenle özellikle hassas verilere ve yönetim işlevlerine erişimde yalnız parola bilgisine dayanılmamalıdır.

Doğrulama Etmenleri

Authentication Factor (doğrulama etmeni), kimliği kanıtlamak için kullanılan kanıtın türünü ifade eder. Temel etmenler Tablo 5'te gösterilmiştir [12].

Tablo 5. Temel Doğrulama Etmenleri

Etmen	Açıklama	Örnek
Bildiğiniz bir şey	Kullanıcının bildiği gizli bilgi	Parola
Sahip olduğunuz bir şey	Kullanıcının kontrolündeki doğrulama aracı	Güvenlik anahtarı veya doğrulama uygulaması bulunan cihaz
Olduğunuz bir şey	Kullanıcının biyometrik özelliği	Parmak izi veya yüz özelliği

Biyometrik özellik, her durumda tek başına bağımsız bir doğrulayıcı olarak değerlendirilmez. Örneğin cihazdaki kriptografik doğrulayıcının parmak iziyle etkinleştirilmesinde, cihazın kontrolü ve biyometrik doğrulama birlikte kullanılır [12].

Çok Etmenli Doğrulama

Multi-Factor Authentication (çok etmenli doğrulama, MFA), kimlik doğrulamada farklı türlerden en az iki etmenin kullanılmasına dayanır. Amaç, tek bir etmenin ele geçirilmesinin hesabı kullanmak için yeterli olmamasıdır [12], [13].

Örneğin parola ile birlikte kullanıcının cihazındaki doğrulama uygulamasının ürettiği kodun istenmesi, bilgi ve sahiplik etmenlerini birleştirebilir. Buna karşılık parola ile güvenlik sorusunun yanıtını istemek, iki bilgi sorulmasına rağmen iki farklı etmen sağlamaz.

İki Aşama ile İki Etmen Arasındaki Fark

Ekranda art arda iki doğrulama adımının bulunması, işlemin mutlaka MFA olduğu anlamına gelmez. Önemli olan adım sayısı değil, kanıtların farklı etmenlere dayanmasıdır. Benzer şekilde, uygun bir cihazda yerel biyometrik doğrulamayla etkinleştirilen kriptografik yöntem, kullanıcıya tek bir işlem gibi görünse de birden fazla etmeni birleştirebilir [12].

Proje teslim sisteminde öğrenciden önce kullanıcı adı, ardından parola istenmesi iki ekran oluşturur. Ancak kullanıcı adı gizli bir kanıt olmadığından bu akış, tek başına MFA sayılmaz.

Yöntemlerin Güvenlik Farkları

Bütün MFA yöntemleri aynı saldırılara karşı eşit koruma sağlamaz. Kullanıcının elle girdiği doğrulama kodları sahte bir sayfada alınarak saldırgan tarafından kullanılabilir. *Phishing-Resistant Authentication (kimlik avına dirençli doğrulama)* yöntemleri, doğrulama işlemini hedef hizmetle kriptografik olarak ilişkilendirerek bu riski azaltmayı amaçlar [12].

Bu nedenle özellikle erişim politikalarını değiştirebilen veya hassas verilere ulaşabilen yönetici hesaplarında kimlik avına dirençli yöntemler tercih edilmelidir. Ancak MFA, başarılı girişten sonraki yetkilendirme kontrollerinin yerine geçmez.

Hesap Kurtarma ve Oturumların Korunması

Doğrulama cihazı kaybolduğunda hesabın nasıl kurtarılacağı da tasarlanmalıdır. Kurtarma yolu zayıfsa saldırgan normal giriş korumalarını bu yol üzerinden aşabilir. Yedek doğrulama araçları ve kurtarma kodları güvenli saklanmalı; bir doğrulayıcının değiştirilmesi uygun kontrollerle korunmalıdır [13].

Örneğin proje sistemi yöneticisinin ikinci doğrulama aracını değiştirme isteği, yalnız gönderilen bir e-postaya dayanarak kabul edilmemelidir. Ayrıca MFA kullanılması, açık bir oturumun ele geçirilmesi riskini tamamen ortadan kaldırmaz. Hesap güvenliği, giriş süreciyle birlikte oturumların ve kurtarma işlemlerinin korunmasını da gerektirir.

3.4. Uygulama ve Servis Kimlikleri

Bulut uygulamaları, çalışmalarını sürdürürken başka kaynaklara erişmek zorundadır. Bir uygulama depolamadan dosya okuyabilir, veritabanına kayıt yazabilir veya başka bir servisi çağırabilir. Bu işlemlerde hedef hizmetin, isteğin hangi uygulamadan geldiğini ve bu uygulamanın hangi işlemlere yetkili olduğunu belirleyebilmesi gerekir.

Workload Identity (iş yükü kimliği), çalışan bir uygulamayı veya yazılım bileşenini temsil eden kimliktir. Bir sanal makinedeki uygulama, bir konteyner veya olay üzerine çalışan bir fonksiyon bu tür bir kimlikle kaynaklara erişebilir. *Service Account (servis hesabı)* ise insan yerine uygulama veya servis tarafından kullanılmak üzere tanımlanan hesap türüdür. Sağlayıcıların bu amaçla sunduğu kimlik mekanizmaları farklılık gösterebilir [14]–[16].

İnsan Hesabı ile Uygulama Kimliğinin Ayrılması

Bir uygulamanın, onu geliştiren kişinin hesabıyla çalıştırılması uygun bir görev ayrımı sağlamaz. Geliştiricinin hesabı uygulamanın ihtiyaç duymadığı yönetim yetkilerine sahip olabilir. Ayrıca kişinin görevinin değişmesi veya kurumdan ayrılması, uygulamanın erişimini de etkileyebilir.

Örneğin rapor işleme servisi, öğretim elemanının kullanıcı adı ve parolasıyla depolamaya bağlanmamalıdır. Servisin kendisine ait kimliği bulunmalı ve izinleri gerçekleştirdiği işlemlerle sınırlandırılmalıdır. Böylece insanın etkileşimli erişimi ile uygulamanın otomatik erişimi ayrı yönetilir.

İnsanlara yönelik MFA akışı da uygulamalara aynı biçimde uygulanmaz. Sürekli çalışan bir servisin her işlemde bir kişinin doğrulama kodu girmesini beklemesi uygun değildir. Bunun yerine çalışma ortamının desteklediği uygulama kimliği ve otomatik kimlik doğrulama mekanizmaları kullanılır.

Kimliğin Çalışan Uygulamayla İlişkilendirilmesi

Desteklenen bulut ortamlarında bir kimlik, ilgili iş yüküyle ilişkilendirilebilir. Uygulama, platformun sunduğu mekanizma üzerinden gerekli kimlik bilgilerini alarak hedef hizmete erişir. Bu yaklaşım, geliştiricinin kaynak koda kalıcı bir erişim anahtarı ekleme gereksinimini azaltabilir [14], [15].

Ancak iki ayrı karar verilmelidir:

- Kimliği kullanma hakkı: Hangi iş yükü bu kimlikle çalışabilir?
- Kaynağa erişim hakkı: Bu kimlik hangi kaynaklarda hangi işlemleri yapabilir?

Uygulamaya bir kimlik bağlanması, bütün kaynaklara otomatik erişim verilmesi anlamına gelmez. Aynı şekilde güçlü bir kimliği başka iş yüklerine bağlayabilen bir yönetim yetkisi de dikkatle sınırlandırılmalıdır.

Göreve ve Ortama Göre Kimlik Ayrımı

Birbirinden farklı görevleri olan uygulamaların aynı geniş yetkili kimliği paylaşması, bir bileşenin ele geçirilmesi durumunda erişilebilecek kaynakları artırır. Test ve üretim ortamlarının aynı kimlik bilgilerini kullanması da bu ortamlar arasındaki güvenlik sınırını zayıflatabilir.

Tablo 6. Proje Teslim Sisteminde Uygulama Kimliklerinin Ayrılması

Bileşen	Kimliğin Görevi	Gerekli Erişim Örneği	Gerekmeyen Yetki Örneği
Teslim uygulaması	Kullanıcı isteklerini işlemek	İzin verilen teslimleri kaydetmek ve okumak	Bulut kullanıcılarına rol atamak
Rapor işleme servisi	Raporları işleyip sonuç üretmek	Belirli girdileri okumak ve sonuç alanına yazmak	Diğer uygulamaların sırlarını okumak
Bildirim servisi	İşlem sonucunu kullanıcıya bildirmek	Bildirim için gerekli sonuç bilgisini almak	Rapor içeriklerini değiştirmek

Tablo 6 örnek bir görev ayrımını göstermektedir. Her uygulama kimliğinin izinleri, bileşenin gerçek veri akışı ve görev kapsamına göre belirlenmelidir.

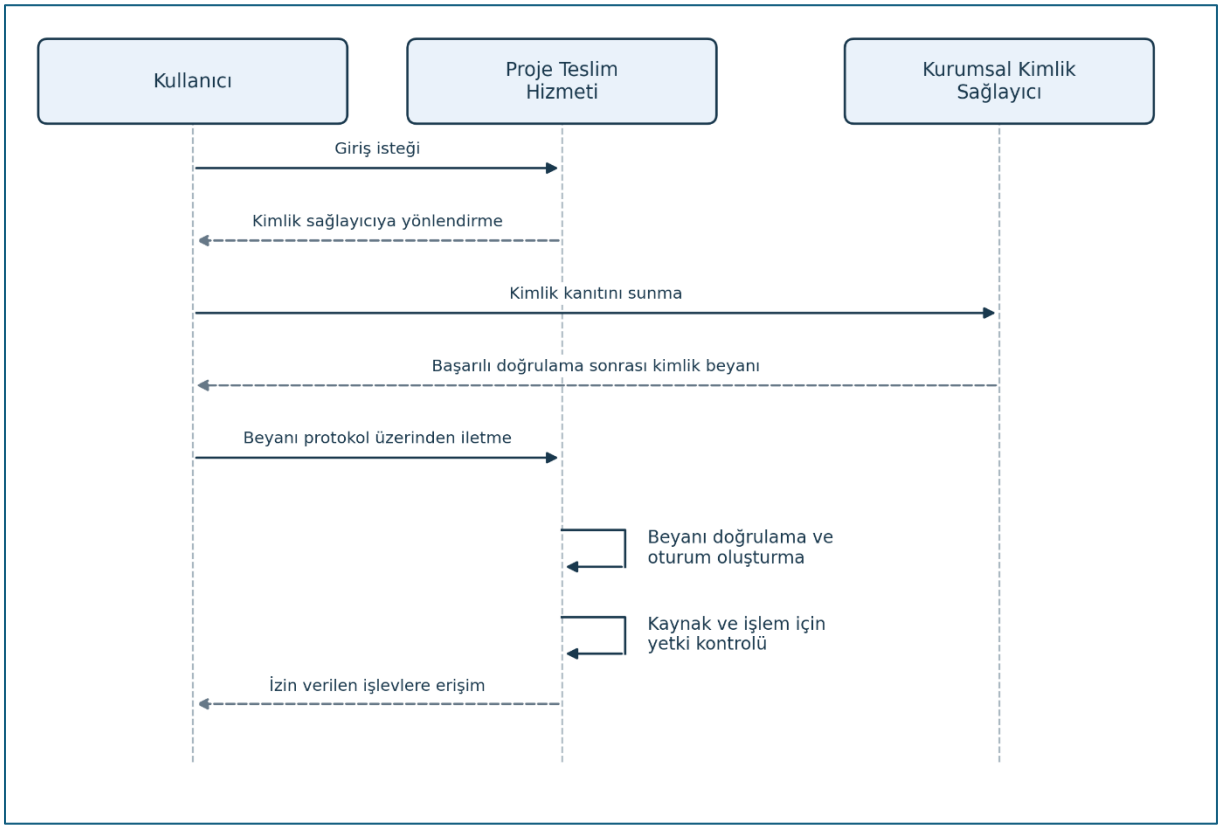
Üç Sağlayıcıdaki Kavramsal Karşılıklar

Amazon Web Services'te IAM rolleri, uygun iş yüklerine geçici kimlik bilgileriyle erişim sağlayabilir [14]. Microsoft Azure'da Managed Identity (yönetilen kimlik), desteklenen kaynaklarda kimlik bilgilerinin yönetimini platforma bırakarak uygulama erişimini kolaylaştırır [15]. Google Cloud'da servis hesapları, uygulamaların kaynak erişiminde kullanılan insan dışı kimliklerdir [16].

Bu mekanizmaların ortak amacı, uygulamanın kendi kimliğiyle ve belirlenmiş izinlerle çalışmasını sağlamaktır. Kimlik bilgilerinin platform tarafından yönetilmesi, izinlerin doğru tasarlanması gereğini ortadan kaldırmaz.

3.5. Federasyon, Kısa Ömürlü Kimlik Bilgileri ve Yaşam Döngüsü

Bir kurum birden fazla bulut hizmeti kullandığında her hizmet için ayrı parola oluşturulması, kullanıcı hesaplarının ve erişimlerin yönetimini zorlaştırabilir. Benzer biçimde, uygulamalara dağıtılan uzun ömürlü erişim anahtarları zaman içinde kodda veya yapılandırma dosyalarında unutulabilir. Federasyon ve kısa ömürlü kimlik bilgileri, bu sorunları azaltmak için kullanılan yaklaşımlardır.



Şekil 3. Kullanıcının kurumsal kimliğiyle proje teslim hizmetine erişmesine ilişkin basitleştirilmiş federasyon akışı.

Kimlik Federasyonu

Identity Federation (kimlik federasyonu), bir sistemin başka bir sistem tarafından doğrulanan kimlikten, tanımlanmış bir güven ilişkisi üzerinden yararlanmasıdır. Kullanıcının kimliğini doğrulayan taraf *Identity Provider (kimlik sağlayıcı, IdP)* olarak adlandırılır. Hedef uygulama, kullanıcının parolasını doğrudan doğrulamak yerine kimlik sağlayıcının ilettiği doğrulanabilir kimlik beyanını değerlendirir [17].

Örneğin bir öğrenci, üniversitenin kurumsal hesabıyla proje teslim hizmetine giriş yapabilir. Öğrencinin parolası kurumsal kimlik sağlayıcı tarafından doğrulanır; proje hizmeti kendisine sunulan beyanın güvenilirliğini kontrol eder. Böylece proje hizmetinin öğrenci için ayrıca bir parola yönetmesi gerekmeyebilir.

Bu yapı, *Single Sign-On (tek oturum açma, SSO)* deneyimini destekleyebilir. Kullanıcı, kurumsal oturumu üzerinden birden fazla hizmete erişebilir. Ancak federasyon kimlikler arasındaki güven ilişkisini, SSO ise kullanıcının giriş deneyimini ifade eder; her hizmetin erişim izinleri ayrıca değerlendirilir.

Şekil 3 kavramsal bir akıştır; beyanın iletilme biçimi kullanılan protokole göre değişebilir. Hedef hizmet, beyanın beklenen sağlayıcıdan geldiğini, kendisi için düzenlendiğini ve geçerli olduğunu kontrol etmelidir. Federasyon, dışarıdan gelen her kimliğin veya beyanın koşulsuz kabul edilmesi değildir [17].

Kısa Ömürlü Kimlik Bilgileri

Kısa ömürlü kimlik bilgileri, belirli bir süre sonunda geçerliliğini kaybeden güvenlik bilgileridir. Uzun süre değişmeden kullanılan bir erişim anahtarı yerine, ihtiyaç sırasında alınan ve süresi dolduğunda yenilenen bilgiler kullanılabilir [18].

Örneğin rapor işleme servisi, çalışma ortamının desteklediği mekanizmayla geçici kimlik bilgileri alabilir. Bu bilgilerin süresi dolduğunda uygun koşullar sağlanıyorsa yenileri alınır. Uygulamanın kaynak kodunda kalıcı bir anahtar saklama ihtiyacı azaltılmış olur.

Kısa ömürlü kimlik bilgileri, sızan bilginin kullanılabileceği süreyi sınırlar; ancak verilen izinlerin kapsamını daraltmadığından en az ayrıcalık ilkesiyle birlikte kullanılmalıdır.

İş Yüklerinde Federasyon

Federasyon yalnız insan kullanıcılar için kullanılmaz. *Workload Identity Federation (iş yükü kimlik federasyonu)*, uygun bir dış ortamda çalışan uygulamanın kimlik kanıtının bulut tarafında değerlendirilerek kaynak erişiminde kullanılmasını sağlar. Bu yaklaşım, dış uygulamaya indirilebilir ve uzun ömürlü bir servis hesabı anahtarı dağıtma gereksinimini azaltabilir [19].

Burada da hangi dış kimliğin kabul edileceği ve hangi kaynaklara erişebileceği sınırlandırılmalıdır. Güvenilir bir kimlik sağlayıcı kullanılması, o sağlayıcının doğruladığı bütün iş yüklerine aynı yetkinin verilmesini gerektirmez.

Kimlik Yaşam Döngüsünün Yönetilmesi

Kimlik yönetimi, hesabın oluşturulmasıyla tamamlanmaz. Erişim ihtiyacı değiştikçe kimlik ve izinler de güncellenmelidir:

- **Oluşturma:** Kimliğin sahibi, amacı ve kullanım ortamı belirlenir.
- **Kullanım:** Uygun doğrulama yöntemi ve görev için gerekli izinler uygulanır.
- **Değişiklik:** Görev, proje veya ortam değiştiğinde erişimler gözden geçirilir.
- **Sonlandırma:** İhtiyaç sona erdiğinde hesap, kimlik ilişkileri ve ilgili erişim yolları kapatılır.

Örneğin bir öğretim elemanının proje değerlendirme görevi bittiğinde, kurumsal hesabı kullanılmaya devam etse bile ilgili projeye erişimi kaldırılmalıdır. Kullanımdan kaldırılan bir rapor servisinin kimliği de başka bir uygulamaya kontrolsüz biçimde devredilmemelidir.

Merkezî hesabın kapatılması, bütün hizmetlerdeki mevcut oturumların veya geçici kimlik bilgilerinin her durumda anında geçersiz olacağını garanti etmez. Bu nedenle erişimin kaldırılmasında yeni girişlerin engellenmesi, mevcut oturumların durumu ve geçerli kimlik bilgilerinin sona erme veya iptal davranışı birlikte değerlendirilmelidir.

4. Yetkilendirme ve En Az Ayrıcalık

Kimliği doğrulanan bir kullanıcı veya uygulama için hangi kaynaklarda hangi işlemlerin yapılabileceği ayrıca belirlenmelidir. Bu bölümde erişim isteklerinin nasıl değerlendirildiği, izinlerin roller ve nitelikler üzerinden nasıl tanımlandığı ve görev için gerekli sınırlarla nasıl daraltıldığı ele alınacaktır. Ardından bulut kaynaklarına verilen izinler ile uygulamanın kendi kullanıcılarına uyguladığı erişim kontrolleri arasındaki ilişki açıklanacaktır.

4.1. Erişim İsteği ve Yetkilendirme Kararı

Yetkilendirme, bir kimliğe genel olarak “güvenilir” veya “güvenilmez” etiketi vermekten daha ayrıntılı bir değerlendirmedir. Aynı kullanıcı belirli bir dosyayı okuyabilirken başka bir dosyaya erişemeyebilir; aynı dosyayı okuyabilirken silemeyebilir. Bu nedenle karar, erişim isteğinin bütünü üzerinden verilmelidir.

Erişim İsteğinin Bileşenleri

Bir erişim isteğini değerlendirmek için dört temel bilgi birlikte ele alınır: isteği yapan özne, istenen işlem, hedef kaynak ve geçerli koşullar. Sağlayıcıların politika dilleri farklı olsa da bu bileşenler erişim kurallarını açıklamak için ortak bir çerçeve sunar [20].

Tablo 7. Erişim isteğinin temel bileşenleri

Bileşen	Yanıtladığı Soru	Örnek
Subject (özne)	İsteği kim yapıyor?	Öğretim elemanı hesabı veya rapor işleme servisi
Action (işlem)	Ne yapılmak isteniyor?	Okuma, yazma, silme veya rol atama
Resource (kaynak)	İşlem hangi varlık üzerinde yapılacak?	Belirli bir rapor, depolama alanı veya kullanıcı hesabı
Condition (koşul)	Erişim hangi şartlarda geçerli?	Atanmış proje, çalışma ortamı veya izin verilen zaman aralığı

Özne, yalnız insan kullanıcı olmak zorunda değildir. Bir uygulama kendi kimliğiyle dosya okuduğunda özne uygulamadır. Kaynak da yalnız bir sunucu değildir; tek bir dosya veya sır değeri gibi daha dar kapsamlı bir varlık olabilir.

Politikanın İsteğe Uygulanması

Policy (politika), erişime ilişkin kuralları tanımlar. Bir politika, belirli öznelerin hangi kaynaklarda hangi işlemleri yapabileceğini ve varsa ek koşulları belirtir [20].

Örneğin proje teslim sisteminde şu kural tanımlanmış olsun:

Öğretim elemanı, kendisine atanmış projenin test ortamındaki raporlarını okuyabilir.

Bu kuralın uygulanabilmesi için yalnız kullanıcının öğretim elemanı olduğunun bilinmesi yeterli değildir. İstenen işlemin okuma olması, raporun atanmış projeye ait olması ve ortamın test olması da değerlendirilmelidir.

- Atanmış projenin test raporunu okuma isteği, belirtilen kuralla uyumludur.
- Başka bir projenin test raporunu okuma isteği, proje sınırını karşılamaz.
- Atanmış projenin üretim raporunu okuma isteği, ortam koşulunu karşılamaz.
- Atanmış projenin test raporunu silme isteği, izin verilen işlemi aşar.

Bu sonuçlar, örnekte yalnız bu izin kuralının bulunduğu varsayımına dayanır. Gerçek bir sistemde isteğe uygulanabilen diğer politikalar da hesaba katılır.

Varsayılan Ret Yaklaşımı

Deny by Default (varsayılan ret), erişimi haklı kılan geçerli bir izin bulunmadığında isteğin reddedilmesidir. "Bu işlemi yasaklayan bir kural yok" düşüncesi, tek başına erişim gerekçesi sayılmaz [11].

Örneğin yukarıdaki politika rapor okumaya izin vermektedir. Rapora ilişkin silme işlemi için ayrıca geçerli bir izin yoksa silme isteği reddedilmelidir. Her olası yetkisiz işlem için ayrı bir yasak yazılması beklenmez.

Varsayılan ret ile belirli bir erişimi özellikle yasaklayan *Explicit Deny (açık ret)* aynı şey değildir. İlki uygun izin bulunmamasına, ikincisi uygulanabilir bir yasak kuralına dayanır. İzin ve ret kurallarının birlikte değerlendirilme biçimi, kullanılan politika sistemine göre incelenmelidir.

Kararda Kullanılan Bilginin Güvenilirliği

Erişim kararı doğru kurallara dayansa bile girdiler güvenilir değilse sonuç hatalı olabilir. Kullanıcının isteğe "rolüm yönetici" veya "projem A" yazması, bu bilgilerin doğru kabul edilmesi için yeterli değildir. Rol ve proje ilişkileri, doğrulanmış kimlikle bağlantılı güvenilir kayıtlardan alınmalı veya bu kayıtlarla kontrol edilmelidir.

Benzer biçimde, bir dosyanın yalnız adından hareketle hangi projeye ait olduğu varsayılmamalıdır. Hedef kaynak güvenilir bilgilerle belirlenmeli ve yetki kontrolü o kaynak üzerinde uygulanmalıdır. Değerlendirme için gerekli bir bilgi eksikse erişim kontrolsüz biçimde açılmamalıdır. Böylece politika, yalnız doğru biçimde hazırlanmış örnek isteklerde değil, beklenmeyen isteklerde de güvenli sınırı korur.

4.2. Rol ve Nitelik Tabanlı Erişim Denetimi

Bir sistemde her kullanıcı için izinleri tek tek tanımlamak, kullanıcı ve kaynak sayısı arttıkça yönetimi zorlaştırır. Erişim denetimi modelleri, izinlerin tutarlı kurallarla düzenlenmesini sağlar. Bu amaçla yaygın kullanılan iki yaklaşım, rol tabanlı ve nitelik tabanlı erişim denetimidir.

Rol Tabanlı Erişim Denetimi

Role-Based Access Control (rol tabanlı erişim denetimi, RBAC) yaklaşımında izinler roller altında toplanır; kullanıcılar veya uygulama kimlikleri uygun rollere atanır. Böylece aynı görevi yapan kimliklere benzer izinlerin verilmesi kolaylaşır [21].

Proje teslim sisteminde örneğin şu roller bulunabilir:

- Rapor okuyucu: Belirlenen raporları okuyabilir.
- Rapor işleyici: Girdileri okuyabilir ve sonuçları yazabilir.

- Erişim yöneticisi: Yetkili olduğu kapsamda rol atamalarını düzenleyebilir.

Bir öğretim elemanına rapor okuyucu rolü verilmesi, rolün içerdiği okuma işlemlerini kullanmasını sağlar. Ancak rolün hangi kaynaklarda geçerli olduğu da belirtilmelidir. Yalnız rol adını bilmek, erişimin kapsamını anlamaya yetmez.

Örneğin rapor okuyucu rolü yalnız A projesinin kaynakları üzerinde atanmışsa bu atama, B projesinin raporlarını okuma izni vermez. Rolün adı "okuyucu" olsa da içerdiği gerçek izinler ayrıca incelenmelidir.

Nitelik Tabanlı Erişim Denetimi

Attribute-Based Access Control (nitelik tabanlı erişim denetimi, ABAC) yaklaşımında karar; öznenin, kaynağın, istenen işlemin ve gerektiğinde ortamın niteliklerini değerlendiren kurallara dayanır [22].

Örnek nitelikler şunlardır:

- Özne: Atanmış proje, birim veya onay düzeyi.
- Kaynak: Ait olduğu proje, çalışma ortamı veya hassasiyet sınıfı.
- İşlem: Okuma, güncelleme veya silme.
- Ortam: İsteğin zamanı veya doğrulanmış bağlantı bağlamı.

Örneğin "öğretim elemanı, kendisine atanmış projenin test ortamındaki raporlarını okuyabilir" kuralında proje ve ortam bilgileri erişimi sınırlandırmak için kullanılabilir. Proje ataması değiştiğinde erişim kararı, güncellenen güvenilir niteliklere göre değerlendirilebilir.

Tablo 8. Rol ve nitelik tabanlı erişim denetiminin karşılaştırılması

Karşılaştırma Noktası	RBAC	ABAC
Temel yaklaşım	İzinleri görev rollerinde toplar	Nitelikleri politika koşullarıyla değerlendirir
Örnek	A projesinde rapor okuyucu rolü	Öznenin projesi ile kaynağın projesinin eşleşmesi
Yönetim avantajı	Ortak görevlerin izinlerini düzenlemeyi kolaylaştırır	Tekrarlanan erişim koşullarını ortak kurallarla ifade edebilir
Dikkat edilmesi gereken nokta	Rol içerikleri, atama kapsamları ve gereksiz roller	Niteliklerin doğruluğu ve kuralların anlaşılabilirliği

Tablo 8'deki yaklaşımlar birbirini dışlamaz. Seçim, yalnız modelin adına göre değil, erişim gereksinimlerinin nasıl daha açık ve yönetilebilir ifade edilebildiğine göre yapılmalıdır.

İki Yaklaşımın Birlikte Kullanılması

Birleşik bir tasarımda rol, yapılabilecek işlemleri belirlerken nitelik koşulları bu işlemlerin hangi kaynaklarda ve şartlarda kullanılacağını daraltabilir. Microsoft Azure'un desteklenen kaynak ve işlemler için sunduğu rol atama koşulları, bu yaklaşımın sağlayıcı örneklerinden biridir [23].

Ders kapsamında aşağıdaki öğretim kuralını kullanalım:

Rapor okuyucu rolü bulunan bir kimlik, yalnız proje ve ortam bilgileri kendisiyle eşleşen raporları okuyabilir.

Ayşe'nin rolü rapor okuyucu, projesi A ve ortamı test olsun. A projesinin test raporunu okuma isteği bu kuralla uyumludur. B projesinin test raporu proje koşulunu; A projesinin üretim raporu ortam koşulunu karşılamaz. A projesinin test raporunu silme isteği ise nitelikler eşleşse bile rol silmeye izin vermediğinden reddedilir.

Bu örnek, rol ve koşulların birlikte sınandığı basitleştirilmiş bir modeldir. Gerçek hizmetlerde desteklenen nitelikler ve diğer izin yollarının karara etkisi ayrıca doğrulanır.

Niteliklerin Güvenilir Biçimde Yönetilmesi

ABAC kuralları, değerlendirdikleri nitelikler güvenilir olduğunda anlamlıdır. Kullanıcı kendi proje bilgisini veya bir kaynağın güvenlik sınıfını serbestçe değiştirebiliyorsa erişim sınırını dolaylı olarak aşabilir. Bu nedenle nitelikleri oluşturma ve değiştirme yetkileri de korunmalıdır [22].

Örneğin Ayşe'nin erişemediği bir raporun proje niteliğini B'den A'ya değiştirebilmesi, okuma kuralını etkisizleştirebilir. Dolayısıyla yalnız "Kim okuyabilir?" sorusu değil, "Erişim kararında kullanılan bilgileri kim değiştirebilir?" sorusu da yanıtlanmalıdır.

4.3. En Az Ayrıcalık ve Etkili İzinler

Least Privilege (en az ayrıcalık), bir kullanıcıya veya uygulamaya yalnız görevini yerine getirmek için gerekli yetkilerin verilmesidir. Amaç, hem hatalı işlemlerin hem de bir kimliğin ele geçirilmesinin doğurabileceği etkiyi sınırlandırmaktır [11].

Bu ilke yalnız yönetici yetkisi vermemek anlamına gelmez. Bir uygulamanın bütün kurum dosyalarını okuyabilmesi, silme izni bulunmasa bile görevi için gereğinden geniş bir erişim olabilir.

İzinlerin İşlem, Kaynak ve Süre Açısından Sınırlandırılması

Yetki tasarımında önce yapılacak iş belirlenir; ardından bu işin gerektirdiği işlemler, kaynaklar ve erişim süresi tanımlanır.

Tablo 9. En az ayrıcalığın üç boyutu

Boyut	Sorulacak Soru	Örnek Sınırlandırma
İşlem	Hangi işlemler gerçekten gerekli?	Rapor okumaya izin verilir; silme ve rol atama verilmez.
Kaynak	İşlem hangi kaynaklarda yapılmalı?	Yalnız A projesinin girdi alanına erişilir.
Süre	Yetki ne kadar süre gerekli?	Geçici bakım erişimi iş tamamlandığında kaldırılır.

Örneğin rapor işleme servisi, A projesinin girdilerini okuyup sonuç alanına yazıyorsa bütün depolama alanlarını yönetme yetkisine ihtiyaç duymaz. Girdi ve çıktı alanlarının izinleri de farklı olabilir: girdiler için okuma, sonuçlar için yazma izni tanımlanabilir.

Süre sınırı ile kimlik bilgisinin geçerlilik süresi birbirinden ayrılmalıdır. Kısa ömürlü kimlik bilgisi sona erse bile aynı geniş yetkilerle yenisi alınabiliyorsa kalıcı yetki sorunu devam eder. Geçici bir göreve ilişkin erişimin, görev sona erdiğinde ayrıca kaldırılması gerekir.

Etkili İzinlerin Belirlenmesi

Effective Permissions (etkili izinler), bir kimliğin belirli bir istekte fiilen kullanabildiği yetkilerdir. Bu yetkiler yalnız kimliğe doğrudan atanmış bir rolden gelmeyebilir. Grup üyelikleri, üst kapsamdan gelen atamalar ve kaynak üzerindeki politikalar da kararı etkileyebilir [24], [25].

Örneğin Ayşe'ye A projesinde yalnız rapor okuma rolü atanmış olsun. Ayşe aynı zamanda A projesinde yazma ve silme yetkisi bulunan bir grubun üyesiyse doğrudan rolünün dar olması, fiilî erişiminin de dar olduğunu göstermez. Uygulanabilir diğer sınırlamalar bulunmadığında grup üzerinden ek yetkiler kullanabilir.

Bu nedenle geniş bir izni düzeltmek için aynı kullanıcıya dar bir rol daha atamak yeterli olmayabilir. İzni sağlayan diğer yollar bulunmalı ve uygun biçimde düzenlenmelidir.

İzinlerin birleşmesi her sistemde yalnız toplama işlemi değildir. Bazı politika türleri izin sağlarken bazıları üst sınır veya ret uygular. Örneğin AWS'de belirli politika türleri arasında birleşim, bazı sınırlandırıcı politikalarla ise kesişim değerlendirmesi yapılır; uygulanabilir açık retler kararı engelleyebilir [24]. Azure RBAC'de rol atamaları eklemeli çalışır; uygulanabilir ret atamaları ve koşullar da değerlendirilir [25]. Bu davranışlar tek bir evrensel kurala indirgenmemelidir.

Yetki Yükseltme Riski

Privilege Escalation (yetki yükseltme), bir tarafın sahip olması gerekenden daha güçlü yetkiler elde etmesidir. Bu durum yalnız doğrudan yönetici rolü verilmesiyle oluşmaz. Başka kimliklerin rollerini değiştirebilmek veya güçlü bir kimlikle çalışan uygulamanın kodunu değiştirebilmek de dolaylı erişim yolları oluşturabilir.

Örneğin dosya okuma izni bulunmayan bir kullanıcı, kendisine dosya okuyucu rolü atayabiliyorsa mevcut izin listesinde okuma yetkisinin görünmemesi yeterli koruma sağlamaz. Benzer biçimde, rapor servisinin çalıştırdığı kodu değiştirebilen bir kişi, servis kimliğinin yetkilerini kötüye kullanabilir.

Bu nedenle yalnız mevcut veri işlemleri değil, kimlikleri, politikaları ve çalışan yazılımı değiştirme yetkileri de incelenmelidir.

İzinlerin Gözden Geçirilmesi ve Doğrulanması

Görev değişiklikleri ve geçici çalışmalar nedeniyle zaman içinde gereksiz yetkiler birikebilir. Eski grup üyelikleri, tamamlanmış projelerin erişimleri ve geçici bakım izinleri düzenli olarak gözden geçirilmelidir [11].

Bir erişim hatasını çözmek için kullanıcıya tüm kaynaklarda yönetici yetkisi vermek yerine başarısız isteğin kimliği, işlemi, kaynağı ve koşulları belirlenmelidir. Gerekli izin dar kapsamda düzenlendikten sonra hem işin yapılabildiği hem de ilgisiz kaynaklara erişimin reddedildiği sınanmalıdır. Örneğin rapor servisinin A projesini okuyabilmesiyle birlikte B projesini okuyamaması ve hiçbir projede rol atayamaması da doğrulanmalıdır.

4.4. Yönetim Yetkileri ve Uygulama Erişim Sınırları

Bir bulut kaynağını oluşturmak veya yapılandırmak ile o kaynağın içindeki verileri kullanmak farklı işlemlerdir. Benzer şekilde, uygulamanın bir dosyaya erişebilmesi, uygulamayı kullanan herkesin aynı dosyaya erişebileceği anlamına gelmez. Güvenli bir tasarımda bu yetki alanları ayrı değerlendirilmelidir.

Yönetim İşlemleri ile Veri İşlemlerinin Ayrılması

Control Plane (kontrol düzlemi), kaynakların oluşturulması, yapılandırılması ve yönetilmesiyle ilgili işlemleri kapsar. *Data Plane (veri düzlemi)* ise hizmetin sunduğu veri işlemlerini kapsar. Örneğin bir sır saklama hizmetinin ağ ayarlarını değiştirmek yönetim işlemiyken, saklanan bir parolanın değerini almak veri işlemidir. Azure Key Vault bu iki erişim alanını ayrı arayüzler ve izinlerle ele alan bir sağlayıcı örneğidir [26].

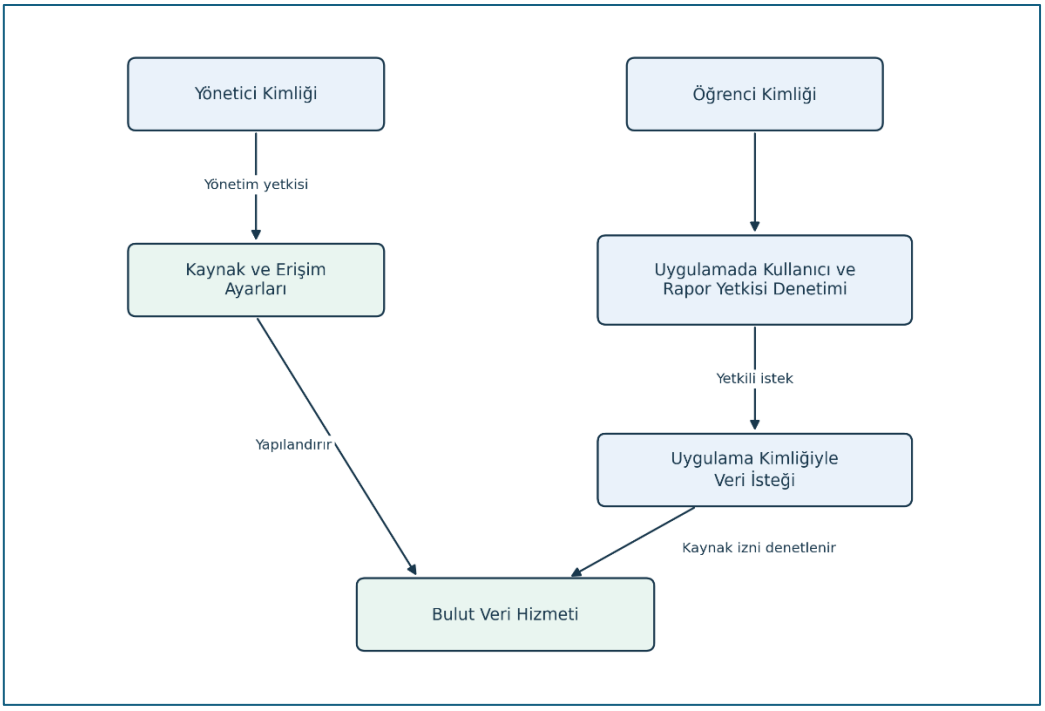
Bu ayrım sayesinde bir teknik görevli kaynağın yapılandırmasını yönetebilirken uygulama, yalnız ihtiyaç duyduğu içeriğe erişecek şekilde yetkilendirilebilir. Ancak ayrımın gerçekten sağlanıp sağlanmadığı, kullanılan rollerin izinleri incelenerek belirlenir. Bir rolün adında "yönetici" veya "okuyucu" bulunması tek başına yeterli bilgi değildir.

Örneğin rapor depolama hizmetinin bağlantı ayarlarını değiştirmek, raporları okumak ve raporların erişim politikasını değiştirmek üç farklı yetki gereksinimidir. Bunların aynı kişide veya uygulamada toplanması, işin gereği olup olmadığına göre değerlendirilmelidir.

Kontrol ve veri düzlemlerinin ayrılması, yönetim yetkilerinin veriye dolaylı erişim sağlayıp sağlamadığı da incelendiğinde anlam kazanır. Bölüm 4.3'te açıklanan yetki yükseltme yolları nedeniyle, doğrudan veri okuma izninin bulunmaması tek başına yeterli güvence değildir [25], [26].

Bulut İzni ile Uygulama İzninin Ayrılması

Proje teslim uygulamasının kendi kimliğiyle depolama hizmetine bağlandığını düşünelim. Depolama hizmeti, uygulamanın ilgili raporu okuma iznini değerlendirir. Öğrencinin raporu görme hakkını ise uygulamanın ayrıca denetlemesi gerekir.



Şekil 4. Uygulamanın kendi kimliğiyle veri hizmetine eriştiği bir tasarımda yönetim, kullanıcı ve uygulama yetkilerinin ayrılması.

Burada iki farklı soru vardır:

- Uygulama açısından: Bu öğrenci bu raporu okumaya yetkili mi?

- Bulut hizmeti açısından: İsteği yapan uygulama kimliği bu nesneyi okumaya yetkili mi?

Uygulama kimliğine verilmiş izin, son kullanıcı için otomatik bir erişim hakkı oluşturmaz. Kullanıcıların kaynaklarla ilişkisine dayanan yetkilendirme kontrolleri sunucu tarafında uygulanmalıdır [11].

Şekil 4'te yönetim yolu, kaynağın ve erişim kurallarının düzenlenmesini gösterir. Kullanıcı yolu ise hem uygulama içindeki rapor yetkisine hem de uygulama kimliğinin bulut izinlerine bağlıdır.

5. Sıfır Güven ve Katmanlı Erişim

Bulut ortamında kullanıcılar farklı konumlardan bağlanabilir, uygulamalar farklı platformlarda çalışabilir ve veriler birden fazla hizmette tutulabilir. Bu yapıda güvenlik kararlarını yalnız kurum ağının sınırlarına dayandırmak yeterli değildir. Kaynağa erişen tarafın kimliği, erişim bağlamı ve uygulanabilir güvenlik kontrolleri birlikte değerlendirilmelidir. Bu bölümde sıfır güven yaklaşımı ve farklı güvenlik katmanlarının birbirini nasıl tamamladığı ele alınacaktır.

5.1. Sıfır Güven Yaklaşımı ve Erişim Bağlamı

Zero Trust (sıfır güven), bir kullanıcıya veya cihaza yalnız ağ konumu ya da kuruma ait olması nedeniyle örtük güven verilmemesini esas alan güvenlik yaklaşımıdır. Koruma, yalnız ağın çevresine değil, erişilmek istenen kaynaklara ve bu kaynaklara yönelik isteklere odaklanır [27].

Örneğin üniversite ağına bağlı bir bilgisayardan gelen istek, yalnız bu bağlantı nedeniyle bütün raporlara erişebilmemelidir. Bilgisayar zararlı yazılım tarafından ele geçirilmiş veya geçerli bir kullanıcı oturumu başka biri tarafından kullanılmaya başlanmış olabilir. Benzer şekilde, kurum dışından gelen bir istek de yalnız konumu nedeniyle mutlaka reddedilmek zorunda değildir; uygun kimlik, yetki ve bağlam kontrolleriyle değerlendirilebilir.

Erişim Bağlamının Değerlendirilmesi

Erişim kararı oluşturulurken sistemin desteklediği ve güvenilir biçimde elde edebildiği bilgiler kullanılabilir:

- Kimlik ve doğrulama durumu: İsteği hangi kimlik yapmaktadır ve hangi doğrulama yöntemi kullanılmıştır?
- Cihaz veya iş yükü durumu: Kullanılan cihaz ya da uygulama, tanımlanan güvenlik gereksinimlerini karşılamakta mıdır?
- Kaynak ve işlem: İstek herkese açık bir duyuruya mı, hassas bir rapora mı yoksa yönetim işlevine mi yöneliktir?
- Risk ve davranış bilgileri: Oturum veya kullanım biçiminde ek inceleme gerektiren bir değişiklik var mıdır?

Bu bilgiler her sistemde aynı kapsamda bulunmayabilir. Politika, hangi bilgilerin gerekli olduğunu ve bunların doğrulanamaması durumunda nasıl davranılacağını belirlemelidir [27], [28].

Örneğin bir öğretim elemanının duyuruları görüntülemesi ile çok sayıda öğrenci raporunu dışarı aktarması aynı etkiye sahip değildir. Kurumun politikasına göre ikinci işlem için yönetilen bir cihaz, daha güçlü doğrulama veya ek onay gerekebilir. Kullanıcının rolü değişmese bile hedef işlemin hassasiyeti erişim koşullarını değiştirebilir.

Koşullar Değiştiğinde Kararın Yeniden Değerlendirilmesi

Başlangıçta izin verilen bir erişimin koşulları daha sonra değişebilir. Hesabın riskli olarak işaretlenmesi, cihazın güvenlik gereksinimlerini artık karşılamaması veya geçici görevin sona ermesi bu duruma örnektir. Uygun sistemlerde bu değişiklikler erişimin sınırlandırılmasına, yeniden doğrulama istenmesine veya oturumun sonlandırılmasına yol açabilir [28].

Bu yaklaşım, her istekte kullanıcıya yeniden parola sorulması anlamına gelmez. Güncel oturum ve bağlam bilgileriyle kararın uygun noktalarda değerlendirilmesini gerektirir. Değişikliklerin ne kadar hızlı uygulanabileceği, kullanılan hizmetin yeteneklerine bağlıdır.

Sıfır güven, tek bir ürünün kurulmasıyla tamamlanan bir özellik değildir. Kimlik, yetki, cihaz, ağ ve veri koruma kararlarının ortak bir güvenlik yaklaşımıyla düzenlenmesidir.

5.2. Katmanlı Güvenlik Kontrollerinin Birlikte Uygulanması

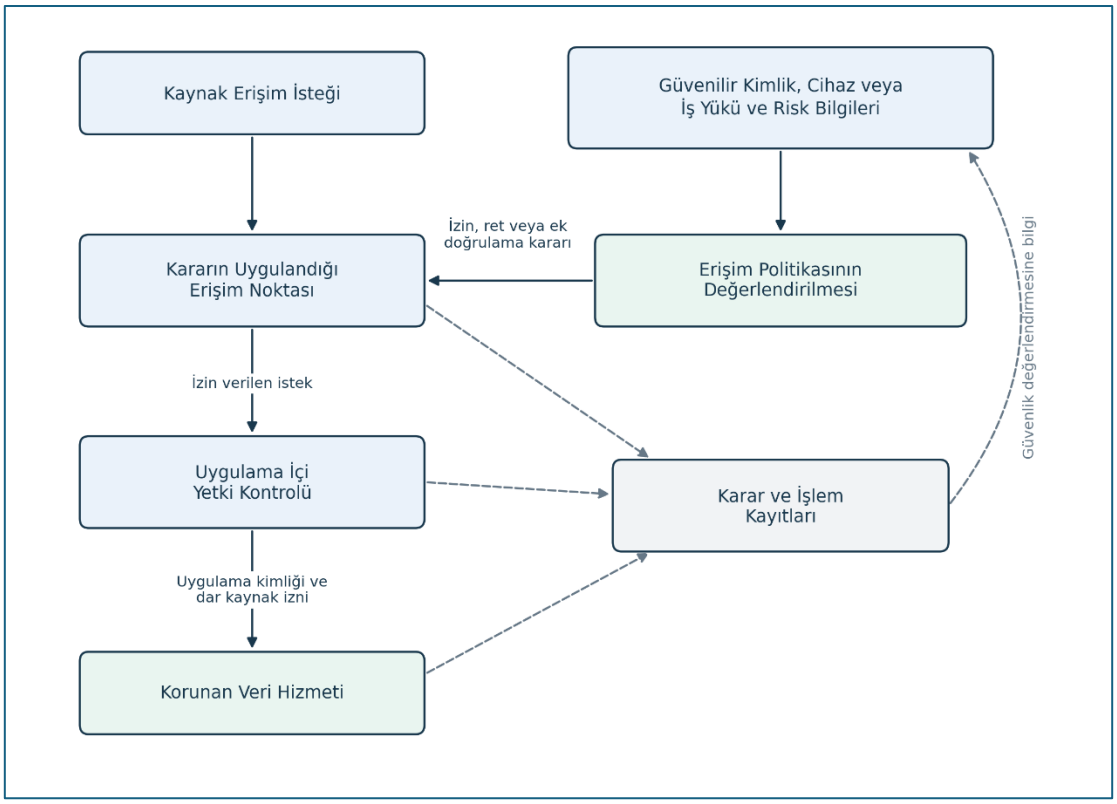
Defense in Depth (derinlemesine savunma), güvenliğin tek bir kontrole bağlı bırakılmamasıdır. Farklı kontroller, farklı zayıflıkları ele alır ve bir kontrolün aşılması durumunda olayın etkisini sınırlandırmaya yardımcı olur. Sıfır güven yaklaşımı da saldırganın ortamın içinde bulunabileceği varsayımıyla erişimlerin dar tutulmasını ve olayın yayılmasının sınırlandırılmasını destekler [28].

Örneğin güçlü kimlik doğrulama, yanlış verilmiş bir dosya iznini düzeltmez. Ağ kısıtlaması da izin verilen uygulamanın ele geçirilmesi hâlinde bütün veri erişimlerini engellemez. Kontroller, hangi riski karşıladıkları bilinerek birlikte tasarlanmalıdır.

Tablo 10. Katmanlı tasarımda güvenlik kontrollerinin katkıları

Kontrol Alanı	Temel Katkısı	Tek Başına Çözmediği Durum
Ağ erişimi	Hangi bileşenlerin iletişim kurabileceğini sınırlar.	İzin verilen bağlantıdaki kullanıcının dosya hakkını belirlemez.
Kimlik ve oturum	İsteğin doğrulanmış bir kimlikle ilişkilendirilmesini sağlar.	Kimliğin bütün işlemlere yetkili olduğunu göstermez.
Kaynak izinleri	Uygulamanın erişebileceği bulut kaynaklarını daraltır.	Son kullanıcının iş nesnesi üzerindeki hakkını kendiliğinden denetlemez.
Uygulama yetkilendirmesi	Kullanıcı, işlem ve iş nesnesi ilişkisini denetler.	Ele geçirilmiş uygulamanın bütün davranışlarını tek başına sınırlandıramaz.
Veri koruma	Aktarımda ve depolamada uygun şifreleme sağlar.	Yetkili erişim yoluyla açık verinin kötüye kullanılmasını mutlaka engellemez.
Denetim kayıtları	Kararların ve işlemlerin incelenmesine kanıt sağlar.	Kayda alınan her yetkisiz işlemi doğrudan engellemez.

Tablo 10, ders senaryosu için hazırlanmış bir kontrol eşleştirmesidir. Kontrollerin yalnız sayıca fazla olması yeterli değildir; korudukları sınırlar ve aralarındaki bağımlılıklar anlaşılmalıdır.



Şekil 5. Erişim bağlamı, politika kararı, uygulama denetimi ve kaynak izinlerinin birlikte kullanıldığı kavramsal güvenlik akışı.

Şekil 5 belirli bir ürünün mimarisi değildir. Kararın verilmesi ile uygulanmasının farklı görevler olduğunu gösterir. Kayıtların değerlendirmeye katkısı da her kaydın anında ve otomatik olarak erişimi değiştirdiği anlamına gelmez.

Bir Kontrol Aşıldığında Diğer Katmanların Katkısı

Rapor işleme uygulamasının ele geçirildiğini düşünelim. Uygulama kimliğinin yalnız belirli proje girdilerini okuyabilmesi ve sonuç alanına yazabilmesi, saldırganın diğer projelere erişimini sınırlandırır. Ağ kuralları ilgisiz hizmetlere bağlantıları kısıtlarken yönetim yetkilerinin bulunmaması, erişim politikalarının değiştirilmesini engellemeye yardımcı olur. Bununla birlikte saldırgan, uygulamaya izin verilmiş işlemleri gerçekleştirebilir. Katmanlı kontrollerin amacı, bir ihlal sonrasında da saldırganın hareket alanını ve oluşabilecek zararı azaltmaktır.

Tasarımın Doğrulanması

Doğrulamada yalnız “yetkili kullanıcı erişebiliyor mu?” sorusu sorulmamalıdır. Proje değiştiğinde, gerekli cihaz bilgisi bulunmadığında veya hassas bir işlem istendiğinde politikanın beklenen sonucu üretip üretmediği de sınanmalıdır.

Her testte kimlik, hedef kaynak, işlem, ilgili koşullar ve karar kaydedilebilir. Parola ve gizli kimlik bilgileri bu kayıtlara yazılmamalıdır. Böylece kontrollerin varlığı kadar, birlikte çalışırken korumaları gereken sınırları sürdürdükleri de gösterilebilir.

6. Sırlar ve Uygulama Kimlik Bilgilerinin Yönetimi

Uygulamaların kullandığı veritabanı parolaları ve dış hizmetlere erişim anahtarları, açıklanmaları durumunda yetkisiz erişime yol açabilir. Bu bilgilerin güvenliği, yalnız saklandıkları yerle sınırlı

değildir. Uygulamaya nasıl sağlandıkları, değiştirildiklerinde nasıl güncellendikleri ve sızıntı durumunda nasıl geçersiz kılındıkları da birlikte tasarlanmalıdır.

6.1. Sırların Güvenli Saklanması ve Uygulamaya Sağlanması

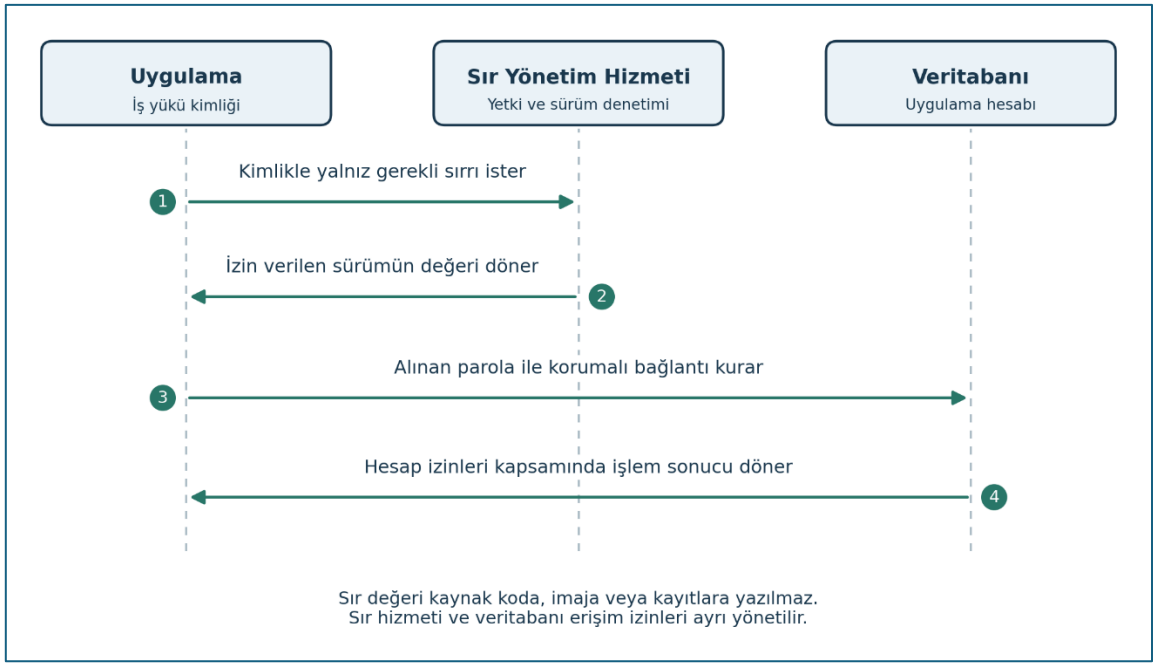
Secret (sır), açıklanması bir kaynağın güvenliğini tehlikeye atabilecek gizli bilgidir. Veritabanı parolası ve bir hizmete erişim sağlayan gizli anahtar bu kapsamdadır. Sunucu adresi, ortam adı veya bağlantı zaman aşımı gibi yapılandırma değerleri ise her durumda sır değildir [29].

Sırların kaynak koda veya uygulama imajına eklenmesi, bu içeriğe ulaşabilen kişilerin aynı bilgileri elde etmesine yol açabilir. Bir sırrın daha sonra dosyadan silinmesi de eski sürümlerde veya imaj katmanlarında kalan kopyaları ortadan kaldırmayabilir. Hata çıktıları ve uygulama kayıtları da sırların yanlışlıkla açıklanabileceği yerlerdir.

Merkezi Saklama ve Kontrollü Erişim

Secrets Management (sır yönetimi) hizmeti, sırların merkezi olarak saklanmasını, erişimlerinin sınırlandırılmasını ve sürümlerinin yönetilmesini sağlar. Uygulama, kendi kimliğiyle yalnız ihtiyaç duyduğu sırra erişir. Sır hizmetine bağlanmak için kaynak koda ikinci bir kalıcı parola yazılması yerine, desteklenen platform kimliği veya federasyon mekanizmasından yararlanılabilir [29], [30].

Örneğin proje teslim uygulamasının veritabanı parolası sır hizmetinde tutulabilir. Uygulama çalışırken izin verilen sürümü alır ve veritabanı bağlantısında kullanır. Bu örnekte uygulamanın sır hizmetindeki kimliği ile veritabanında kullandığı hesap ayrı erişim alanlarıdır.



Şekil 6. Uygulamanın kendi kimliğiyle gerekli sırrı alması ve bu bilgiyi veritabanına erişimde kullanması.

Şekil 6'da sır değeri, kullanıcıya gösterilen bir çıktı değildir. Uygulamanın ihtiyaç duyduğu anda, korumalı iletişim üzerinden aldığı güvenlik bilgisidir. Veritabanı kimlik tabanlı erişimi destekliyorsa kalıcı parola gereksiniminin azaltılması da değerlendirilebilir.

Çalışma Anında Koruma

Sırrın merkezi hizmette tutulması, uygulamaya alındıktan sonraki güvenliği tek başına sağlamaz. Değerin bellekte veya önbellekte tutulması, hata dökümlerine yazılması ve gereksiz kopyalarının

oluşturulması da değerlendirilmelidir. Önbellekleme kullanılıyorsa sırrın yenilenmesini uygulamaya yansıtacak bir güncelleme düzeni bulunmalıdır [30], [31].

Ortam değişkeni veya dosya kullanılması da tek başına güvenlik garantisi değildir. Erişim izinleri, kullanım süresi ve sızıntı yolları önemlidir. Test ve üretim ortamlarında aynı sırların paylaşılması ise bir ortamda yaşanan ihlalin diğerini etkilemesine neden olabilir.

6.2. Sırların Yenilenmesi, İptali ve Sızıntıya Müdahale

Secret Rotation (sır yenileme), kullanılan gizli bilginin yenisiyle değiştirilmesi sürecidir. Bir veritabanı parolasının yenilenmesi, yalnız sır hizmetine yeni bir değer yazmak değildir. Hedef veritabanının kabul ettiği parola ile uygulamanın kullandığı değer uyumlu olmalıdır [32].

Tablo 11. Veritabanı parolasını yenilerken ele alınacak adımlar

Adım	Yapılacak İş	Doğrulama
Hazırlık	Yeni değer ve geçiş yöntemi belirlenir.	Etkilenen uygulamalar ve hesaplar bilinir.
Hedefi güncelleme	Yeni bilgi veritabanında etkinleştirilir.	Yeni bilgiyle bağlantı kurulabilir.
Uygulamaya geçiş	Sır sürümü ve uygulamanın kullandığı değer güncellenir.	Yeni bağlantılar başarılıdır.
Eski değeri iptal	Geçiş tamamlanınca eski bilgi geçersiz kılınır.	Eski bilgiyle yeni bağlantı kurulamaz.

Tablo 11 kavramsal bir akıştır. Adımların kesin sırası ve eski ile yeni bilginin birlikte geçerli olabileceği süre, hedef sistemin desteklediği yönteme bağlıdır. Tek parola kabul eden bir hesapla, geçiş sırasında iki ayrı hesap kullanılabilen bir sistem aynı biçimde yönetilmez [32].

Örneğin sır hizmetindeki değer güncellenmiş olsa bile uygulama önbellekteki eski parolayı kullanabilir. Veritabanı parolasının değiştirilmesi de mevcut bağlantıları her sistemde anında sonlandırmaz. Bu nedenle yeni bağlantılarla birlikte mevcut bağlantıların durumu da kontrol edilmelidir.

Sızıntı Durumunda Müdahale

Bir parola kaynak kod deposunda veya uygulama kaydında açığa çıktıysa yalnız görünen kopyayı silmek yeterli değildir. Bilginin kopyalanmış olabileceği kabul edilerek ilgili erişim sınırlandırılmalı, sır yenilenmeli veya iptal edilmeli ve olası kötüye kullanım incelenmelidir [29].

Planlı yenilemede hizmet sürekliliği gözetilerek kontrollü geçiş yapılabilir. Doğrulanmış bir sızıntıda ise saldırganın erişimini kesmek için eski bilginin daha erken iptal edilmesi gerekebilir. Müdahale sonrasında sızıntının nedeni de giderilmelidir; aksi hâlde yeni sır aynı yoldan tekrar açığa çıkabilir.

AWS Secrets Manager, Azure Key Vault ve Google Cloud Secret Manager bu amaçla kullanılan hizmet örnekleridir. Ancak merkezi sır saklama ile otomatik yenileme aynı yetenek değildir. Yenilemenin hedef sisteme uygulanması, uygulamaya yansıtılması ve eski değerin iptali için desteklenen entegrasyon ayrıca doğrulanmalıdır [30]–[32].

7. Şifreleme ve Anahtar Yönetimi

Bulutta şifreleme, verinin okunabilir içeriğini kriptografik bir anahtar kullanılarak korur. Ancak bu korumanın etkinliği, şifrelemenin hangi aşamada uygulandığına, anahtarın kim tarafından

kullanılabildiğine ve anahtarın yaşam döngüsünün nasıl yönetildiğine bağlıdır. Bu bölümde şifreleme, bulutta veri saklama ve uygulama çalıştırma senaryoları üzerinden ele alınmaktadır.

7.1. Bulutta Şifrelemenin Kullanımı ve Sınırları

Bulut uygulamalarında veri, ağ üzerinden taşınırken ve depolama ortamlarında tutulurken farklı risklerle karşılaşır. Bu nedenle şifreleme iki temel kullanım üzerinden değerlendirilir:

- *Encryption in Transit (aktarımda şifreleme)*: İstemci, uygulama ve bulut hizmetleri arasında taşınan veriyi korur.
- *Encryption at Rest (depolamada şifreleme)*: Disklerde, nesne depolama alanlarında, veri tabanlarında ve yedeklerde tutulan veriyi korur. [33]

Aktarımda şifreleme için yaygın olarak *Transport Layer Security (taşıma katmanı güvenliği, TLS)* kullanılır. Örneğin bir öğrencinin raporunu bulut uygulamasına yüklemesi sırasında TLS, bağlantıdaki verinin gizliliğini ve bütünlüğünü korur. Sunucunun kimliğinin doğrulanabilmesi için sertifikanın geçerliliği ve bağlanılan sunucu adı da denetlenmelidir.

Bir bağlantının TLS ile korunması, verinin uygulamaya kadar geçtiği bütün bağlantıların otomatik olarak korunduğu anlamına gelmez. TLS bir yük dengeleyicide sonlandırılıyorsa yük dengeleyici ile arka uç uygulaması arasındaki bağlantı ayrıca değerlendirilmelidir. [34]

Depolamada şifreleme ise verinin saklandığı ortamı korur. Ancak uygulamanın veriyi okumaya yetkili olması durumunda bulut hizmeti veriyi çözerek uygulamaya sunabilir. Dolayısıyla yanlış yetkilendirilmiş bir uygulamanın veriyi okuması, depolamada şifreleme açık olsa bile mümkün olabilir.

Şifrelemenin uygulandığı yer de güven sınırını değiştirir:

- *Hizmet tarafında şifrelemede* bulut hizmeti, veriyi depolarken şifreler ve yetkili okuma işlemlerinde çözer.
- *Uygulama tarafında şifrelemede* uygulama, veriyi depolama hizmetine göndermeden önce şifreler. Bu yaklaşım, anahtar yönetimi sorumluluğunu artırır; şifreli içerik üzerinde arama ve veri işleme olanaklarını sınırlayabilir. [33]

Örneğin bir rapor arşivinde hizmet tarafında şifreleme temel korumayı sağlayabilir. Daha dar bir erişim sınırı gereken hassas raporlarda ise uygulama tarafında şifreleme değerlendirilebilir. Karar verilirken yalnız verinin hassasiyeti değil, kimlerin açık veriye erişmesi gerektiği ve uygulamanın hangi işlemleri gerçekleştireceği de dikkate alınmalıdır.

7.2. Anahtar Yönetimi ve Zarf Şifreleme

Key Management Service (anahtar yönetim hizmeti, KMS), kriptografik anahtarların oluşturulmasını, korunmasını ve yetkili işlemlerde kullanılmasını yöneten hizmet yaklaşımıdır. AWS KMS, Azure Key Vault anahtar hizmetleri ve Google Cloud KMS bu alandaki örneklerdir. Hizmetlerin ayrıntıları farklılaşsa da temel amaç, anahtar kullanımını denetlenebilir bir güvenlik sınırı içinde tutmaktır. [33], [35], [36]

Önceki bölümdeki sır yönetimi ile anahtar yönetimi arasında önemli bir fark vardır: Uygulama, sır yönetim hizmetinden veri tabanı parolasını alarak kullanabilir. Anahtar yönetim hizmetinde ise uygun anahtar türlerinde kriptografik işlem, korunan anahtar uygulamaya verilmeden gerçekleştirilebilir.

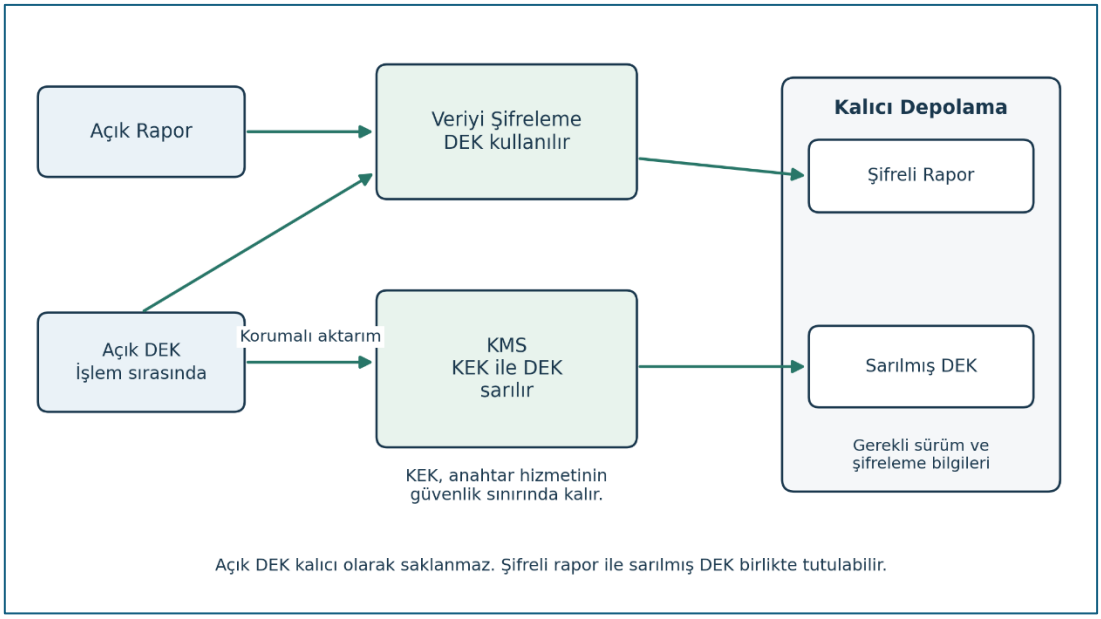
Sağlayıcı tarafından yönetilen anahtarlarda anahtar yönetiminin büyük bölümü bulut hizmetine bırakılır. Müşteri tarafından yönetilen anahtarlar ise anahtarın kullanım izinleri ve yaşam döngüsü üzerinde müşteriye daha fazla denetim sağlar. Müşterinin anahtarı yönetmesi, ham anahtar malzemesini indirmesi veya uygulama içinde saklaması gerektiği anlamına gelmez. [35]

Büyük miktarda verinin korunmasında yaygın bir yaklaşım *Envelope Encryption (zarf şifreleme)* yöntemidir. Bu yöntemde iki anahtarın görevleri ayrılır:

- *Data Encryption Key (veri şifreleme anahtarı, DEK)*: Asıl veriyi şifreler.
- *Key Encryption Key (anahtar şifreleme anahtarı, KEK)*: DEK'i şifreleyerek korur. Bu işlem, anahtarın sarılması olarak adlandırılır. [36]

Şekil 7'deki rapor arşivinde işlem şu şekilde yürütülür:

1. Uygulama, raporu bir DEK kullanarak şifreler.
2. DEK, KMS içindeki KEK ile sarılır.
3. Şifreli rapor ve sarılmış DEK, gerekli şifreleme bilgileriyle birlikte saklanır. Açık DEK kalıcı olarak saklanmaz.
4. Rapor okunacağında yetkili işlem, sarılmış DEK'in çözülmesini sağlar; elde edilen DEK ile rapor çözülür. [36]



Şekil 7. Uygulama tarafında zarf şifreleme örneği: Veri DEK ile, DEK ise KMS içinde korunan KEK ile şifrelenir.

Bu modelde KEK, anahtar hizmetinin güvenlik sınırı içinde kalır. Şifreli rapor ile sarılmış DEK'in aynı depolama alanında bulunması mümkündür; raporu okumak için DEK'i çözme yetkisi de gerekir. Bulut depolama hizmetleri, benzer işlemleri kendi içlerinde de gerçekleştirebilir. Uygulama geliştirilirken bu akış güvenilir kriptografi kütüphaneleri veya hizmetlerle uygulanmalıdır.

7.3. Anahtar Yaşam Döngüsü ve Veri Erişimine Etkileri

Bir anahtarın oluşturulması, güvenli kullanım için yeterli değildir. Hangi uygulamaların anahtarı kullanabileceği, anahtarın ne zaman yenileneceği ve kullanım dışına çıkarıldığında hangi verilerin etkileneceği de belirlenmelidir.

Anahtarı kullanma yetkisi ile anahtarı yönetme yetkisi farklı ihtiyaçlardır. Örneğin rapor uygulamasının şifre çözme işlemi yapması gerekebilir; aynı uygulamanın anahtarı silmesine veya erişim politikasını değiştirmesine gerek yoktur. Bu ayrım, önceki bölümlerde ele alınan en az ayrıcalık ilkesinin anahtar yönetimine uygulanmasıdır.

Key Rotation (anahtar yenileme), yeni kriptografik işlemler için yeni anahtar malzemesine veya sürümüne geçilmesini sağlar. Ancak yenileme, daha önce şifrelenmiş bütün verilerin otomatik olarak yeniden şifrelendiği anlamına gelmez. Eski verilerin çözülmesi için önceki anahtar sürümlerine ihtiyaç duyulabilir. [37]

Tablo 12. Anahtar işlemleri ve veriye erişim üzerindeki etkileri.

İşlem	Temel Amaç	Veriye Erişim Açısından Sonuç
Anahtarı Yenileme	Yeni işlemlerde yeni anahtar malzemesi kullanmak	Eski veriler önceki sürümlere bağlı kalabilir.
DEK'i Yeniden Sarma	DEK'i farklı bir KEK veya sürümle korumak	Asıl verinin yeniden şifrelenmesi gerekmeyebilir.
Veriyi Yeniden Şifreleme	Verinin kriptografik korumasını değiştirmek	Veri yeni anahtarla tekrar şifrelenir.
Anahtarı Devre Dışı Bırakma	Anahtar kullanımını durdurmak	Anahtara bağlı işlemler başarısız olabilir; yeniden etkinleştirme mümkün olabilir.
Anahtarı Silme	Anahtarı kalıcı olarak kullanım dışına çıkarmak	Gerekli anahtar kaybolursa veriler çözülemeyebilir.

Tablodaki işlemler birbirinin yerine kullanılamaz. Özellikle bir DEK'in yeni KEK ile yeniden sarılması, rapor içeriğinin yeni bir DEK ile yeniden şifrelenmesinden farklıdır. [36], [37]

Anahtarın devre dışı bırakılmasının etkisi, hizmetin anahtar kullanımına ve önbellekleme davranışına bağlıdır; bütün erişimlerin aynı anda kesileceği varsayılmamalıdır. Silme işlemi öncesinde ise etkin verilerin, eski veri sürümlerinin ve yedeklerin anahtara bağımlılığı kontrol edilmelidir. Kurtarma ve bekleme süreleri hizmete göre değişebilir. [26], [37]

Rapor arşivi örneğinde yeni raporların güncel anahtar sürümünü kullanması, eski raporların önceki sürümden bağımsız olduğu anlamına gelmez. Bu nedenle anahtarın kullanım dışına çıkarılması kararı, yalnız yaşına göre değil, koruduğu verilere hâlâ ihtiyaç duyulup duyulmadığına göre verilmelidir.

8. Bulut Senaryosu: Güvenli Rapor Yükleme ve Paylaşma

Bir üniversitenin, öğrencilerin proje raporlarını yükleyebildiği ve öğretim elemanlarının bu raporları değerlendirebildiği bir bulut uygulaması geliştirdiğini düşünelim. Uygulama; kimlik, yetkilendirme, sır yönetimi ve şifreleme kontrollerinin birlikte uygulanmasını gerektirmektedir.

Senaryo ve Güvenlik Gereksinimleri

Öğrenciler yalnız kendi raporlarını yükleyebilmeli ve görüntüleyebilmelidir. Öğretim elemanları ise yalnız sorumlu oldukları derslerin raporlarına erişebilmelidir. Teknik yöneticilerin sistemi işletme sorumluluğu, bütün raporların içeriğini okuma yetkisini kendiliğinden gerektirmemektedir.

Rapor dosyaları nesne depolama hizmetinde; raporun sahibi, ait olduğu ders ve depolama konumu gibi bilgiler ise bir veri tabanında tutulmaktadır. Kullanıcılar dosyalara uygulama üzerinden erişir. Depolama alanı herkese açık değildir.

Uygulama, bulut hizmetlerine erişmek için kendisine atanmış iş yükü kimliğini kullanır. Bu senaryoda veri tabanının parola ile bağlantı gerektirdiği varsayılmıştır. Bu nedenle veri tabanı parolası bir sır yönetim hizmetinde tutulur.

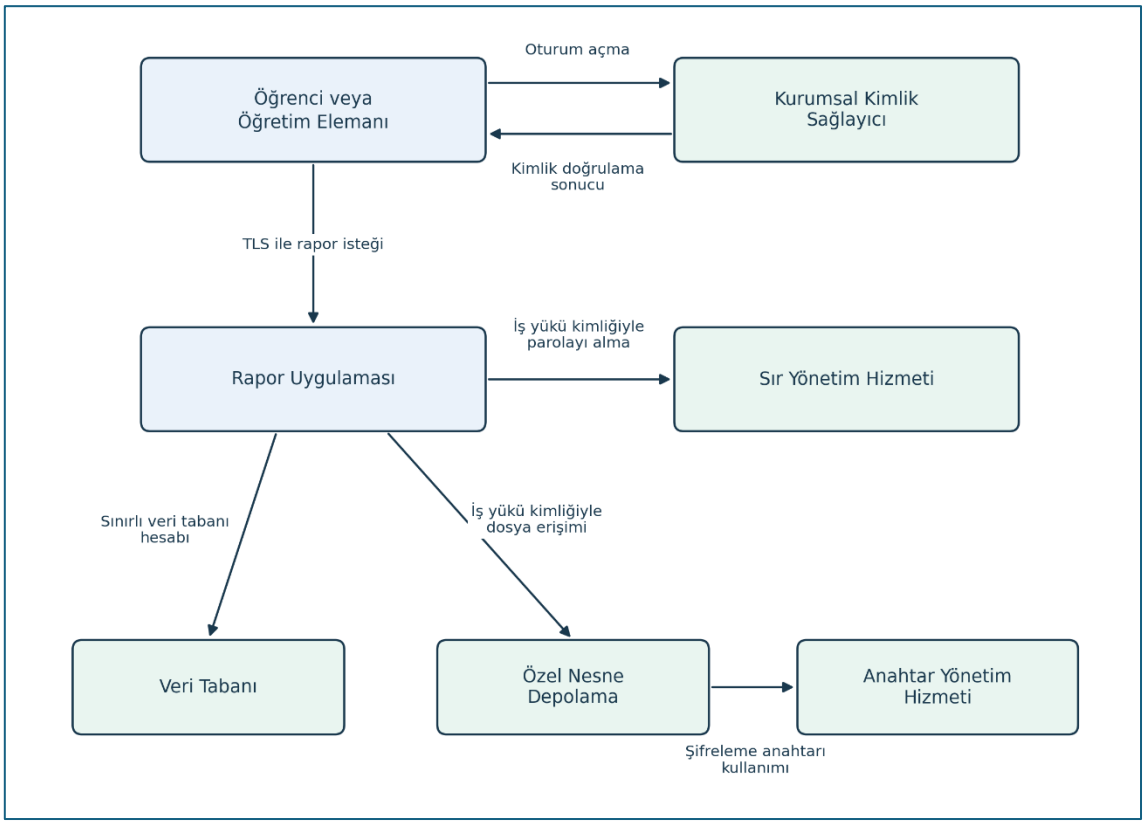
Güvenlik Kararlarının Mimariye Uygulanması

Şekil 8'de sistemin temel bileşenleri ve erişim ilişkileri gösterilmektedir.

Kullanıcıların kimlikleri kurumsal kimlik sağlayıcı üzerinden doğrulanır. Ancak başarılı oturum açma, herhangi bir rapora erişmek için yeterli değildir. Uygulama, her istekte kullanıcının ilgili rapora erişim hakkını ayrıca denetler. Örneğin "öğretim elemanı" rolü, tek başına üniversitedeki bütün derslerin raporlarını görüntüleme hakkı sağlamaz; ders sorumluluğu da değerlendirilir.

Uygulamanın iş yükü kimliğine yalnız ilgili depolama alanındaki gerekli işlemler ve belirli veri tabanı sırrını okuma izni verilir. Uygulama, depolama politikasını değiştiremez veya şifreleme anahtarını silemez. Veri tabanı hesabı da uygulamanın ihtiyaç duyduğu tablolar ve işlemlerle sınırlandırılır.

Parola, uygulama koduna veya konteyner imajına yerleştirilmez; çalışma sırasında sır yönetim hizmetinden alınır. Böylece parola değişikliği için uygulama imajının yeniden oluşturulması gerekmez. Uygulamanın yenilenen parolayı kullanabilmesi ise sır yenileme süreciyle birlikte planlanır.



Şekil 8. Rapor paylaşım uygulamasında kullanıcı erişimi, uygulama kimliği, sır yönetimi ve depolama şifrelemesinin birlikte kullanılması.

Bu senaryoda raporlar, depolama hizmetinin gerçekleştirdiği şifreleme ile korunur. Müşteri tarafından yönetilen anahtarın kullanıldığı modelde, depolama hizmetinin gerekli anahtar işlemlerini yapmasına izin verilir. Uygulamaya doğrudan anahtar yönetim yetkisi verilmesi gerekmez.

Şekil 8'de kullanıcı–uygulama bağlantısında gösterilen TLS koruması, uygulamanın veri tabanı, sır yönetim hizmeti ve nesne depolama hizmetiyle kurduğu bağlantılarda da uygulanmalıdır. Her bağlantıda hedef hizmetin sertifikası doğrulanmalı; bağlantının özel ağ içinde olması, aktarımda şifrelemenin yerine geçmemelidir.

Tablo 13. Rapor paylaşım senaryosunda gereksinimler ve güvenlik kararları.

Gereksinim	Güvenlik Kararı	Gerekçe
Öğrencinin yalnız kendi raporunu okuması	Rapor sahibi ile doğrulanmış kullanıcı kimliğini eşleştirmek	Oturum açmayı, rapora erişim yetkisinden ayırmak
Öğretim elemanının ilgili derslere erişmesi	Rol ile ders sorumluluğunu birlikte denetlemek	Rolün erişim kapsamını gereksiz genişletmemek
Uygulamanın bulut kaynaklarına erişmesi	Sınırlı izinli iş yükü kimliği kullanmak	Kalıcı bulut erişim anahtarlarının uygulamada tutulmasını önlemek
Veri tabanı parolasının korunması	Sır yönetim hizmetinden çalışma sırasında almak	Parolanın kod ve imaj içinde yayılmasını azaltmak
Raporların aktarımda ve depolamada korunması	TLS ve depolama şifrelemesi uygulamak	Ağ aktarımı ile saklama ortamını ayrı ayrı korumak
Anahtar işlemlerinin sınırlandırılması	Anahtar kullanımı ile yönetim yetkilerini ayırmak	Uygulamanın anahtarı değiştirme veya silme yetkisine sahip olmasını önlemek

Bir İsteğin Sistem İçindeki Akışı

Bir öğrencinin daha önce yüklediği raporu görüntülemek istediğini düşünelim:

1. Kimlik doğrulanır. Öğrenci kurumsal hesabıyla oturum açar. Uygulama, kendisine sunulan kimlik bilgisinin geçerliliğini denetler.

2. Rapor erişimi değerlendirilir. Uygulama, istenen raporun sahibini veri tabanından belirler ve doğrulanmış kullanıcıyla karşılaştırır.

3. Dosya uygulama kimliğiyle alınır. Erişim uygunsa uygulama, kendi iş yükü kimliğini kullanarak raporu nesne depolama hizmetinden ister.

4. Depolama şifrelemesi çözülür. Depolama hizmeti, gerekli anahtar işlemlerini gerçekleştirerek raporu uygulamaya sunar.

5. Rapor kullanıcıya iletilir. Uygulama, raporu TLS ile korunan bağlantı üzerinden öğrenciye gönderir.

Bu akışta erişim isteğinin zamanı, isteği yapan kimlik, hedef rapor, istenen işlem ve izin veya ret sonucu denetim kayıtlarına yazılmalıdır. Böylece beklenmeyen erişimler ve tekrarlanan yetkisiz istekler sonradan incelenebilir. Parolalar, gizli anahtarlar ve oturumun ele geçirilmesine imkân verebilecek bilgiler ise kayıtlara yazılmamalıdır.

Bu akışta kullanıcı yetkisi ile uygulama yetkisi farklı amaçlara hizmet eder. Uygulama kimliğinin bir dosyayı okuyabilmesi, o dosyanın istekte bulunan kullanıcıya verilmesini otomatik olarak haklı kılmaz. Kullanıcıya ilişkin erişim denetimi, dosya alınmadan önce uygulamada gerçekleştirilmelidir.

Ayrıca uygulamanın özel ağda bulunması, bu denetimin kaldırılması için gerekçe değildir. Ağ konumu, erişim kararında değerlendirilebilecek unsurlardan biridir; tek başına güven oluşturmaz.

Rapor yükleme işleminde de kullanıcı, hedef ders ve yapılacak işlem birlikte değerlendirilir. Uygulama, rapor sahibini istekte gönderilen öğrenci numarasından değil, doğrulanmış oturumdan belirlemeli ve öğrencinin hedef derse rapor yükleme hakkını denetlemelidir. Dosyanın depolama konumu uygulama tarafından belirlenmeli; kullanıcıdan gelen bir dosya yolu veya rapor tanımlayıcısı, başka bir öğrencinin raporunun üzerine yazılmasına imkân vermemelidir.

Hatalı Yapılandırmanın Sonucu

Uygulamanın, rapor sahibini kontrol etmeden istekte belirtilen rapor numarasına göre dosyayı döndürdüğünü varsayalım. Bir öğrenci, rapor numarasını değiştirerek başka bir öğrencinin raporuna erişebilir.

Bu durumda TLS doğru çalışabilir, depolama alanı özel olabilir ve raporlar şifreli tutulabilir. Buna rağmen uygulamadaki eksik yetkilendirme denetimi veri gizliliğinin ihlal edilmesine yol açar. Sorunun çözümü, rapor numarasını tahmin etmeyi zorlaştırmakla sınırlı değildir; her rapor isteğinde kullanıcı ile kaynak arasındaki erişim ilişkisini doğrulamaktır.

Senaryo, güvenliğin yalnız bir hizmet ayarına bağlı olmadığını göstermektedir. Kimlik doğrulama, uygulama içi yetkilendirme, kaynak izinleri, sır yönetimi ve şifreleme kararları aynı veri erişim akışı içinde birbirini tamamlamaktadır.

9. Bölüm Özeti

Bulut güvenliği; verilerin gizliliğini, bütünlüğünü ve kullanılabilirliğini korumak için kimlik, erişim, ağ ve veri koruma kararlarının birlikte tasarlanmasını gerektirir. Güvenlik sorumlulukları sağlayıcı ile müşteri arasında paylaşılır. Kullanılan hizmetin yönetilen olması, müşterinin kullanıcı izinlerini, paylaşım tercihlerini ve uygulama güvenliğini doğru düzenleme sorumluluğunu ortadan kaldırmaz.

Kimlik doğrulama, isteği yapan tarafın kimliğini kanıtlamasını; yetkilendirme ise bu tarafın belirli bir kaynak üzerinde istenen işlemi yapıp yapamayacağının değerlendirilmesini sağlar. İnsan hesaplarında çok etmenli doğrulama, uygulamalarda ise göreve özel iş yükü kimlikleri ve uygun olduğunda kısa ömürlü kimlik bilgileri kullanılır. Kimliklerin ve erişimlerin oluşturulması, güncellenmesi ve sonlandırılması birlikte yönetilmelidir.

Erişim kuralları roller ve nitelikler üzerinden düzenlenebilir. En az ayrıcalık, izinlerin işlem, kaynak ve süre bakımından görevle sınırlandırılmasını gerektirir. Bir kimliğin gerçek yetkileri değerlendirilirken doğrudan atamalarla birlikte grup üyelikleri, diğer politikalar ve dolaylı yetki yükseltme yolları da incelenmelidir. Uygulamanın bulut kaynağına erişim izni, son kullanıcının uygulama içindeki erişim hakkından ayrıca denetlenir.

Sıfır güven yaklaşımı, yalnız ağ konumuna veya kurum üyeliğine dayanarak güven verilmemesini esas alır. Kimlik, kaynak, işlem ve güvenilir bağlam bilgileri erişim kararında birlikte değerlendirilir.

Katmanlı kontroller ise bir güvenlik önlemi aşıldığında saldırganın hareket alanını ve oluşabilecek zararı sınırlandırmayı amaçlar.

Parolalar ve gizli erişim bilgileri koddan ve uygulama imajından ayrı yönetilmelidir. Merkezi sır yönetimi; kontrollü erişim, yenileme ve iptal süreçleriyle tamamlanır. Bir sırrın yenilenmesi, hedef sistemin kabul ettiği değer ile uygulamanın kullandığı değerin uyumlu biçimde değiştirilmesini gerektirir.

Şifreleme, veriyi aktarımda ve depolamada korur; doğru yetkilendirmenin yerine geçmez. Zarf şifrelemede veri anahtarı veriyi, anahtar şifreleme anahtarı ise veri anahtarını korur. Anahtar yenileme, devre dışı bırakma ve silme farklı sonuçlar doğurur; özellikle eski verilere erişimin hangi anahtarlara bağlı olduğu bilinmelidir.

Güvenli bir bulut tasarımında her kontrol, belirli bir gereksinim ve tehditle ilişkilendirilir. Tasarımın yeterliliği; kimlerin hangi işlemleri yapabileceği, hangi erişimlerin reddedileceği ve bir kimlik ya da bileşen ele geçirildiğinde etkinin nasıl sınırlandırılacağı üzerinden değerlendirilir.

Kaynakça

[1] “Shared Responsibility Model - Amazon Web Services (AWS),” Amazon Web Services, Inc. Accessed: Oct. 16, 2026. [Online]. Available: https://aws.amazon.com/compliance/shared-responsibility-model/

[2] msmbaldwin, “Shared responsibility in the cloud - Microsoft Azure.” Accessed: Oct. 16, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/security/fundamentals/shared-responsibility

[3] N. I. of S. and Technology, “Standards for Security Categorization of Federal Information and Information Systems,” U.S. Department of Commerce, Federal Information Processing Standard (FIPS) 199, Feb. 2004. doi: 10.6028/NIST.FIPS.199.

[4] J. T. F. T. Initiative, “Guide for Conducting Risk Assessments,” National Institute of Standards and Technology, NIST Special Publication (SP) 800-30 Rev. 1, Sep. 2012. doi: 10.6028/NIST.SP.800-30r1.

[5] “Threat Modeling | OWASP Foundation.” Accessed: Oct. 19, 2026. [Online]. Available: https://community.owasp.org/Threat_Modeling

[6] “Shared responsibilities and shared fate on Google Cloud | Cloud Architecture Center,” Google Cloud Documentation. Accessed: Oct. 19, 2026. [Online]. Available: https://docs.cloud.google.com/architecture/framework/security/shared-responsibility-shared-fate

[7] “A02 Security Misconfiguration - OWASP Top 10:2025.” Accessed: Oct. 20, 2026. [Online]. Available: https://top10.owasp.org/2025/A02_2025-Security_Misconfiguration/

[8] “Multi Tenant Security - OWASP Cheat Sheet Series.” Accessed: Oct. 20, 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Multi_Tenant_Security_Cheat_Sheet.html

[9] “NIST Special Publication 800-63-4.” Accessed: Oct. 20, 2026. [Online]. Available: https://pages.nist.gov/800-63-4/sp800-63.html

[10] “AWS security credentials - AWS Identity and Access Management.” Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/security-creds.html

[11] “Authorization - OWASP Cheat Sheet Series.” Accessed: Oct. 20, 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

[12] “NIST Special Publication 800-63B.” Accessed: Oct. 20, 2026. [Online]. Available: https://pages.nist.gov/800-63-4/sp800-63b.html

[13] "Multifactor Authentication - OWASP Cheat Sheet Series." Accessed: Oct. 20, 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html
[14] "IAM roles - AWS Identity and Access Management." Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_roles.html
[15] kengaderdus, "Managed identities for Azure resources - Managed identities for Azure resources." Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/entra/identity/managed-identities-azure-resources/overview
[16] "Service accounts overview | Identity and Access Management (IAM)," Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/iam/docs/service-account-overview
[17] "NIST Special Publication 800-63C." Accessed: Oct. 20, 2026. [Online]. Available: https://pages.nist.gov/800-63-4/sp800-63c.html
[18] "Temporary security credentials in IAM - AWS Identity and Access Management." Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_temp.html
[19] "Workload Identity Federation | Identity and Access Management (IAM)," Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/iam/docs/workload-identity-federation
[20] "IAM JSON policy element reference - AWS Identity and Access Management." Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_policies_elements.html
[21] I. T. L. Computer Security Division, "Role Based Access Control | CSRC | CSRC," CSRC | NIST. Accessed: Oct. 20, 2026. [Online]. Available: https://csrc.nist.gov/projects/role-based-access-control
[22] V. Hu *et al.*, "Guide to Attribute Based Access Control (ABAC) Definition and Considerations," National Institute of Standards and Technology, NIST Special Publication (SP) 800-162, Aug. 2019. doi: 10.6028/NIST.SP.800-162.
[23] rolyon, "What is Azure attribute-based access control (Azure ABAC)?" Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/role-based-access-control/conditions-overview
[24] "Policy evaluation logic - AWS Identity and Access Management." Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/IAM/latest/UserGuide/reference_policies_evaluation-logic.html
[25] rolyon, "What is Azure role-based access control (Azure RBAC)?" Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/role-based-access-control/overview
[26] msmbaldwin, "Secure your Azure Key Vault." Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/key-vault/general/secure-key-vault
[27] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "Zero Trust Architecture," National Institute of Standards and Technology, NIST Special Publication (SP) 800-207, Aug. 2020. doi: 10.6028/NIST.SP.800-207.
[28] rayne-wiselman, "Zero Trust as a security foundation." Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/security/zero-trust/zero-trust-overview
[29] "Secrets Management - OWASP Cheat Sheet Series." Accessed: Oct. 20, 2026. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
[30] "Secret Manager best practices," Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/secret-manager/docs/best-practices

[31] msmbaldwin, “Secure your Azure Key Vault secrets.” Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/key-vault/secrets/secure-secrets
[32] “Rotate AWS Secrets Manager secrets - AWS Secrets Manager.” Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/secretsmanager/latest/userguide/rotating-secrets.html
[33] msmbaldwin, “Azure encryption overview.” Accessed: Oct. 20, 2026. [Online]. Available: https://learn.microsoft.com/en-us/azure/security/fundamentals/encryption-overview
[34] “Encryption in transit for Google Cloud | Security,” Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/docs/security/encryption-in-transit
[35] “AWS KMS keys - AWS Key Management Service.” Accessed: Oct. 20, 2026. [Online]. Available: https://docs.aws.amazon.com/kms/latest/developerguide/concepts.html
[36] “Envelope encryption | Cloud Key Management Service,” Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/kms/docs/envelope-encryption
[37] “Key rotation | Cloud Key Management Service,” Google Cloud Documentation. Accessed: Oct. 20, 2026. [Online]. Available: https://docs.cloud.google.com/kms/docs/key-rotation

---

Hafta 8 – Çalışma Soruları

Soruları yanıtlarken yalnız kavramların tanımlarını vermekle yetinmeyiniz; gerekçelerinizi açıklayınız ve gerektiğinde kısa örnekler kullanınız. Senaryo sorularında varsayımlarınızı belirtiniz. Belirli bir bulut sağlayıcısının ürün adlarını veya komutlarını kullanmanız gerekmemektedir.

1. **Güvenlik Hedefleri:** Bir bulut uygulamasında müşteri bilgilerinin yetkisiz kişilerce okunması, sipariş tutarlarının izinsiz değiştirilmesi ve hizmetin erişilemez hâle gelmesi olaylarını gizlilik, bütünlük ve kullanılabilirlik açısından değerlendiriniz. Bir olayın birden fazla hedefi etkileyebileceği bir örnek veriniz.

2. **Varlık, Tehdit ve Güvenlik Açığı:** Bulutta çalışan bir belge arşivinde depolama alanı yanlışlıkla herkese açık bırakılmıştır. Bu durumda korunacak varlığı, tehdit olayını ve güvenlik açığını birbirinden ayırınız. Riski değerlendirirken hangi iki temel unsuru dikkate alırsınız? Uygun bir kontrol öneriniz.

3. **Paylaşılan Sorumluluk:** Bir kurum, kendi yönettiği sanal makinedeki uygulamasını yönetilen bir uygulama platformuna taşımaktadır. İşletim sistemi bakımı, uygulama içi yetkilendirme ve veri paylaşım ayarları açısından sorumlulukların nasıl değişebileceğini açıklayınız. Aynı kurum hazır bir yazılım hizmeti kullanırsa hangi güvenlik görevleri kurumda kalır?

4. **Çok Kiracılık ve Güven Sınırları:** İki şirket aynı bulut uygulamasını kullanmakta, kayıtlar ortak veri tabanında şirket kimliğiyle ayrılmaktadır. Kullanıcının istekte gönderdiği şirket kimliğini kabul etmek neden yeterli değildir? Şirketler arası izolasyon ile aynı şirketteki kullanıcıların erişim sınırlarını ayrı ayrı açıklayınız.

5. **Kimlik ve Kimlik Bilgisi:** Bir kullanıcı hesabı, kullanıcı adı ve parola hangi farklı işlevlere sahiptir? Kullanıcının parolasını değiştirmesi ile hesabının erişim izinlerini değiştirmek arasındaki farkı açıklayınız. Aynı ayrımı bir uygulama kimliği ve onun geçici kimlik bilgileri üzerinden örneklendiriniz.

6. **Kimlik Doğrulama ve Yetkilendirme:** Oturum açmış bir öğrenci kendi sınav sonucunu görebilmekte, başka öğrencilerin sonuçlarını görememektedir. Bu akışta kimlik doğrulama ve yetkilendirmenin görevlerini ayırınız. Arayüzde ilgili bağlantıyı gizlemek neden yeterli değildir? Her istekte yetki denetlenmesi, her istekte yeniden parola girilmesini gerektirir mi?

7. **Çok Etmenli Doğrulama:** Kullanıcı adı–parola, parola–güvenlik sorusu ve parola–cihazdaki doğrulama uygulaması kodu yöntemlerini doğrulama etmenleri açısından karşılaştırınız. İki aşamalı bir girişin neden her zaman çok etmenli doğrulama olmadığını açıklayınız. Hesap kurtarma sürecindeki bir zayıflık bu korumayı nasıl etkileyebilir?

8. **Uygulama Kimlikleri:** Dosya dönüştürme ve bildirim gönderme görevlerini yapan iki servis, geliştiricinin geniş yetkili kişisel hesabıyla çalışmaktadır. Bu tasarımın sorunlarını açıklayınız. Her servis için uygun kimlik ve izin kapsamı öneriniz; test ve üretim ortamlarının ayrımını da değerlendiriniz.

9. **Federasyon ve Erişimin Sonlandırılması:** Bir çalışan, kurumsal hesabıyla birden fazla bulut hizmetine erişmektedir. Kimlik federasyonu ile tek oturum açmanın ilişkisini açıklayınız. Çalışanın görevi sona erdiğinde merkezî hesabının kapatılması neden bütün mevcut oturumların ve geçici kimlik bilgilerinin anında geçersiz olduğunu göstermeyebilir?

10. **Rol ve Nitelik Tabanlı Erişim:** Bir araştırma sisteminde araştırmacılar yalnız atandıkları projelerin test verilerini okuyabilmektedir. Bu gereksinimi rol ve nitelikleri birlikte kullanarak ifade ediniz. Erişim kararında kullanılan proje ve ortam niteliklerini değiştirme yetkisi neden korunmalıdır?

11. **En Az Ayrıcalık ve Etkili İzinler:** Bir kullanıcıya doğrudan yalnız okuma rolü verilmiştir; ancak üyesi olduğu grup üzerinden yazma ve silme izinleri de bulunmaktadır. Kullanıcının etkili izinlerini değerlendiriniz. Kullanıcıya ayrıca daha dar bir rol atamak sorunu çözer mi? İzinleri işlem, kaynak ve süre bakımından nasıl gözden geçirirsiniz?

12. **Yönetim Yetkileri ve Yetki Yükseltme:** Bir görevli dosyaları doğrudan okuyamamaktadır; fakat kendisine rol atayabilmekte ve dosyalara erişen uygulamanın kodunu değiştirebilmektedir. Bu görevlinin verilere erişemediği söylenebilir mi? Kontrol düzlemi, veri düzlemi ve dolaylı yetki yükseltme açısından açıklayınız.

13. **Sıfır Güven:** Kurum ağına bağlı bir cihazdan gelen bütün isteklere izin verilmesi neden uygun değildir? Hassas belgelerin toplu olarak indirilmesi isteğinde kimlik ve role ek olarak değerlendirilebilecek iki bağlam bilgisi öneriniz. Bu bilgiler doğrulanamadığında sistemin davranışı nasıl belirlenmelidir?

14. **Katmanlı Kontroller:** Bir saldırganın uygulamayı ele geçirdiğini varsayınız. Dar kaynak izinleri, ağ kısıtlamaları ve yönetim yetkilerinin ayrılması saldırganın hareket alanını nasıl etkiler? Bu kontroller doğru uygulanmış olsa bile saldırgan hangi işlemleri gerçekleştirebilir?

15. **Sırların Saklanması:** Bir uygulamanın veri tabanı parolası kaynak koda yazılmış ve konteyner imajına eklenmiştir. Parolanın sonradan koddan silinmesi neden yeterli değildir? Sırrın güvenli saklanması ve çalışma sırasında uygulamaya sağlanması için bir yaklaşım öneriniz. Sır hizmetine erişimde kimlik doğrulamanın nasıl sağlanacağını da açıklayınız.

16. **Sır Yenileme ve Sızıntıya Müdahale:** Sır yönetim hizmetindeki veri tabanı parolası değiştirilmiş, fakat uygulama bağlantı hataları vermeye başlamıştır. Hedef veri tabanı, uygulama önbelleği ve mevcut bağlantılar açısından olası nedenleri açıklayınız. Parolanın sızdığı doğrulanırsa planlı yenilemeye göre müdahale önceliği nasıl değişebilir?

17. **Şifrelemenin Kullanımı ve Sınırları:** Bir sistemde kullanıcı–yük dengeleyici bağlantısı TLS ile korunmakta, yük dengeleyici–uygulama bağlantısı ise şifrelenmemektedir. Sistemin aktarımda şifreleme bakımından durumunu değerlendiriniz. Depolamadaki dosyaların şifreli olması, yanlış verilmiş bir okuma izninin etkisini neden ortadan kaldırmaz?

18. **Zarf Şifreleme:** Büyük bir dosyanın zarf şifrelemeyle korunmasını, veri şifreleme anahtarı ve anahtar şifreleme anahtarının görevlerini ayırarak açıklayınız. Hangi bilgiler kalıcı olarak saklanabilir? Dosyanın yeniden okunabilmesi için hangi işlemler gerekir? Anahtar yönetim hizmetinin bu akıştaki yerini gösteren küçük bir diyagram çiziniz.

19. **Anahtar Yaşam Döngüsü:** Anahtar yenileme, veri anahtarını yeniden sarma, veriyi yeniden şifreleme, anahtarı devre dışı bırakma ve anahtarı silme işlemlerini karşılaştırınız. Yeni dosyaların güncel anahtar sürümünü kullanması, eski sürümün güvenle silinebileceğini gösterir mi? Karar vermeden önce hangi bağımlılıkları incelersiniz?

20. **Bütünleşik Güvenlik Tasarımı:** Bulutta çalışan bir sağlık randevu sisteminde hastalar kendi randevularını, hekimler ise görevli oldukları birimin ilgili kayıtlarını görebilmektedir. Uygulama, kayıtları veri tabanında tutmakta ve bir dış bildirim hizmeti kullanmaktadır. İnsan ve uygulama kimliklerini, erişim kurallarını, sır yönetimini ve şifreleme tercihlerini içeren kısa bir güvenlik tasarımı öneriniz. Tasarımınız için izin verilmesi gereken iki ve reddedilmesi gereken iki istek yazınız; denetim kayıtlarında bulunması ve bulunmaması gereken bilgilere örnek veriniz.
